

GREYNOC SECURITY PLAYBOOKS

Transmission & Physical Layer Playbooks

Radio-frequency spectrum, nanometer-scale optical media, and post-quantum cryptography in silicon - detection, response, and the coverage audit behind the collection.

DOCUMENT

GN-PUB-TXPHY-001

PUBLICATION DATE

2026-08-09

SOURCE

GreyNOC/Playbooks

VERSION

v1.1.0

CLASSIFICATION

PUBLIC // GreyNOC Field Reference

DISCIPLINE

Baseline-derived, locally calibrated

Detection is bounded by what you instrument. Passive interception of RF and optical media is undetectable in principle - the control is cryptographic, not telemetric. Every threshold in these playbooks is a deviation from a locally recorded baseline; published absolute values are not portable between sites. An empty alert queue for an uninstrumented band or span is a coverage gap, not a clean result.

PUBLICATION MAP

Contents

01	QA/QC - Physical-Layer & Transmission-Medium Coverage	04	TX-03 - Post-Quantum Cryptography at the Nanometer Scale: Silicon, Physical Attack & the Physics Floor
02	TX-01 - RF & Radio-Spectrum Intrusion Detection & Response	05	CONVENTIONS
03	TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling		

SOURCE: QAQC-physical-layer-coverage.md

QA/QC - Physical-Layer & Transmission-Medium Coverage

Audit scope. Whether the GreyNOC playbook library covers the physical transmission layer - radio-frequency and optical media - as a detection and response domain.

Audited artifact set. All 50 Markdown files at repository root (20 Detection & Response, 27 AI · Post-Quantum · E2EE, plus README.md, CONVENTIONS.md, SECURITY.md) as of this audit.

Verdict. Gap confirmed - the library had zero physical-layer coverage before this audit. Every playbook in both collections begins at Layer 2 or above and treats the transmission medium as trusted, unexamined substrate. Two new playbooks (TX-01, TX-02) were authored to close the highest-consequence portion of that gap; the remainder is enumerated in Section 5 as open work.

Per the house rule - *reproducible or it didn't happen* - every finding below carries the command that produces it.

1. Method

The audit is a term-presence sweep with word boundaries, followed by manual context review of every hit. Word boundaries matter: an unanchored `grep -ric "RF"` returns 163 hits across the library and an unanchored `LTE` returns 53, but **all** of them are substring artifacts (`surface`, `perform`, `filter`, `alternate`). A naive sweep would have reported this domain as covered. It is not.

Reproduce with:

```
for t in 'radio' 'RF' 'spectrum' 'wireless' 'Wi-Fi' '802.11' 'bluetooth' 'cellular' 'LTE' '5G' \
  'GNSS' 'GPS' 'jamming' 'SDR' 'antenna' 'optical' 'photonic' 'fibre?' 'laser' 'DWDM' \
  'OTDR' 'Li-Fi' 'TEMPEST' 'EMSEC' 'air-gap' 'satellite' 'microwave' 'physical layer' \
  'side-channel' 'QKD'; do \
  printf "%-16s %3s %s\n" "$t" "$(grep -riEo "\b($t)\b" *.md | wc -l)" "$(grep -riEl "\b($t)\b" *.md | tr '\n' ' '); \
done
```

2. Findings

F-01 - Zero coverage of radio-frequency media (*pre-existing, now partially closed*)

Twenty-four of the thirty terms swept returned **zero** matches across all 50 files: `radio`, `RF`, `spectrum`, `wireless`, `802.11`, `bluetooth`, `LTE`, `5G`, `GNSS`, `GPS`, `jamming`, `SDR`, `antenna`, `microwave`, `TEMPEST`, `EMSEC`, `air-gap`, `physical layer` - and, per F-02, the entire optical set.

Consequence. The library's Detection & Response collection claims coverage "across the intrusion lifecycle," but a documented initial-access path - an adversary who never touches a network port - had no playbook. D&R-03 `Distributed Port Scan` presumes an IP reconnaissance surface; D&R-17 `Data Exfiltration` enumerates cloud, C2, and alternate *protocols* but no alternate *medium*. ATT&CK T1011 `Exfiltration Over Other Network Medium` and T1200 `Hardware Additions` were unmapped anywhere in the library.

Disposition. Closed for the enterprise-relevant RF bands by TX-01 - RF & Radio-Spectrum Intrusion. Residual gaps in Section 5.

F-02 - Zero coverage of optical media (*pre-existing, now closed*)

optical, photonic, fiber/fibre, laser, DWDM, OTDR, Li-Fi, and QKD each returned **zero** matches across all 50 files.

Consequence - this is the more serious of the two. The AI · PQ · E2EE collection is built on the harvest-now-decrypt-later threat model, and PB-02 Harvest-Now-Decrypt-Later Exposure is explicitly a *bulk-capture detection* playbook. A passive fiber tap is the single highest-yield bulk-capture position available to a well-resourced adversary - it is silent, it is upstream of every application control, and it sees the aggregate. The collection reasoned about what an HNDL adversary would *do with* captured ciphertext without ever addressing where the capture happens. PB-02 had no counterpart describing how the traffic gets harvested at the medium.

Disposition. Closed by TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling, which is cross-referenced from the HNDL threat model.

F-03 - All six incidental hits are contextual, not coverage

Six word-boundary matches exist across four terms. Every one was manually reviewed; none constitutes physical-layer detection content:

File	Line	Term	Actual context	Coverage?
01-password-spraying.md	105	Wi-Fi	Guest Wi-Fi as a shared-NAT false-positive source	No
05-impossible-travel.md	117	satellite	Satellite ISPs as a geolocation-accuracy caveat	No
08-malware-beaconing.md	128	Wi-Fi	MDM check-ins over Wi-Fi as a false positive	No
12-pq-e2ee-realtime-media.md	154	Wi-Fi, cellular	Wi-Fi ↔ cellular handoff as a renegotiation FP	No
08-bugbounty-crypto-implementation-defects.md	97, 197	side-channel	C10 - computational side channels (timing, fault, residue), not electromagnetic	No
20-ai-serving-plane-isolation.md	152	side-channel	Inference timing/cache side channels	No
27-pq-capacity-interoperability-vendor-assurance.md	48	satellite	Satellite paths as an interop test condition	No

The pattern is consistent and worth naming: where the physical layer appears at all, it appears as *something that generates false positives* - never as something that generates detections.

Note on C10 and Section 8.1. The pre-existing C10 – Side-channel, fault and secret-residue exposure class in PB-08 covers computational side channels only. TX-01's electromagnetic emanation (TEMPEST) material and TX-02's optical-emission material are a different physical phenomenon and are deliberately **not** filed under C10. Do not merge them; a triager reading C10 expects a timing or fault oracle.

F-04 - CONVENTIONS.md Section 5 cross-reference notation was two-collection-only (*now closed*)

Section 5 stated that "the two collections number independently" and defined only PB-NN and D&R-NN. Adding a third collection without amending Section 5 would have made TX-NN an undefined citation form and reintroduced exactly the bare-number ambiguity Section 5 exists to prevent.

Disposition. `CONVENTIONS.md` Section 5 amended to define `TX-NN` and to restate the rule as *three* independently numbered collections. `CONVENTIONS.md` Section 8.1 amended to record that the TX track intentionally owns no defect-class prefix.

F-05 - Detection-telemetry honesty applies with unusual force to this track (*advisory*)

`README.md` step 2 already warns that PQ/E2EE detection "depends on handshake- and key-level visibility that many estates do not yet log." For the physical layer the problem is a category worse: the telemetry frequently **cannot be produced at all** without hardware the organization does not own - spectrum sensors, WIPS overlays, OTDR ports, tapped optical monitor ports.

Both new playbooks therefore lead with a telemetry-tier model that states plainly what is detectable at each level of investment, and both state which intrusion classes remain **undetectable** at Tier 0. A playbook that implies a detection an estate cannot actually run is a fabrication under the house rule, whether or not the logic itself is sound.

3. Coverage matrix - transmission medium × library

Medium	Before this audit	After
Ethernet / IP / application protocols	Covered (D&R-01-18, PB-03/09/12)	unchanged
Wi-Fi (802.11)	None	TX-01 Section 5.1
Bluetooth / BLE	None	TX-01 Section 5.2
Cellular (LTE / 5G NR)	None	TX-01 Section 5.3
GNSS reception	None	TX-01 Section 5.4
Sub-GHz ISM / LPWAN (LoRa, Zigbee, Z-Wave, 433/868/915 MHz)	None	TX-01 Section 5.5
Microwave / satellite backhaul	None	TX-01 Section 5.6
Electromagnetic emanation (TEMPEST)	None	TX-01 Section 5.7 (scoped, detection-limited)
Single-mode / multimode fiber	None	TX-02 Section 6
Free-space optical & laser links (incl. orbital ISL)	None	TX-02 Section 6.5
Visible-light comms / Li-Fi / IR	None	TX-02 Section 6.6
Optical air-gap covert channels	None	TX-02 Section 6.7
Ultrasonic / acoustic covert channels	None	still open - see Section 5
NFC / RFID	None	still open - see Section 5
Power-line / conducted emissions	None	still open - see Section 5
Below the medium - the silicon executing the cryptography	None	TX-03 (added after this audit; see Section 7)

4. Conformance check - new TX track against `CONVENTIONS.md`

Both new playbooks were checked against every convention the library enforces:

Requirement	Source	TX-01	TX-02
GreyNOC detection structure (overview -> mapping -> strategy -> indicators -> logic -> example data -> investigation -> FP -> tuning -> response -> escalation -> analyst notes -> summary)	README.md ¶3	Pass	Pass
ATT&CK cited as ID + name; no forced tags where mapping is absent	Section 4	Pass - unmapped phenomena listed explicitly	Pass - same
ATLAS citations carry collection version	Section 4	N/A - no ATLAS mapping	N/A
Example addresses in RFC 5737 / RFC 3849 space	Section 5	Pass	Pass
Detection logic is JSON-shaped pseudocode, not a SIEM query	Section 5	Pass	Pass
Cross-references use the PB-NN / D&R-NN / TX-NN form, never a bare number	Section 5 (as amended, F-04)	Pass	Pass
Standardized PQC names (ML-KEM / ML-DSA), submission names only as aliases	Section 1	N/A	Pass
No defect-class prefix invented outside the Section 8.1 registry	Section 8.1	Pass - no prefix	Pass - no prefix
ROE Section 6/Section 7 applicability	Section 6, Section 7	N/A - neither is a bug-bounty playbook	N/A

Two conformance notes carried forward as deliberate deviations:

1. **ATT&CK tactic placement is annotated, not asserted.** Both playbooks map ICS-matrix techniques (T0860 , T0887 , T0830 , T0814) alongside Enterprise ones. ICS tactic placement differs from Enterprise and both move between ATT&CK versions, so each mapping table carries a re-verification note rather than a bare tactic claim. This follows Section 4's "say so rather than forcing a tag."
2. **Physical-measurement thresholds are parameterized, never hardcoded as universal.** Optical tap-loss and RF noise-floor thresholds depend entirely on link budget, hardware, and environment. Both playbooks require the reader to establish a local baseline and state the detection threshold as a deviation from it. A published absolute number would be unreproducible in any estate but the one it came from.

5. Residual gaps - open work

The TX track does **not** yet cover the following. Each is a legitimate candidate for TX-03 +; none is closed by TX-01 or TX-02, and no playbook should be read as covering them.

- **NFC / RFID** - badge cloning, relay attacks against physical access control. Adjacent to D&R-06 and D&R-15 but a distinct medium with distinct telemetry.
- **Ultrasonic and acoustic covert channels** - air-gap bridging via speakers/microphones, ultrasonic cross-device tracking beacons.
- **Power-line and conducted emissions** - data over power, and conducted EM leakage.

- **Specialist RF protocol families** - ADS-B/avionics, marine AIS, TETRA/P25 land mobile radio, DECT. High consequence in specific verticals, out of scope for a general enterprise track.
- **Optical-layer quantum key distribution as an operational detection surface.** TX-02 Section 9 states the policy position (QKD is not a substitute for PQC, and PQC per CONVENTIONS Section 1 remains the GreyNOC default) but does not provide QKD-specific monitoring content. *(One gap listed here at first audit - the TX track's absence from the compiled PDF - was closed during remediation; see Section 6.5.)*

6. Actions taken

1. Authored `TX-01-rf-spectrum-intrusion.md` - closes F-01.
2. Authored `TX-02-optical-nm-data-transmission-intrusion.md` - closes F-02.
3. Amended `CONVENTIONS.md` Section 5 (three-collection cross-reference notation) and Section 8.1 (TX track owns no defect-class prefix) - closes F-04.
4. Added the Transmission & Physical Layer collection to `README.md` and `index.html`.
5. Extended the PDF builder to a multi-publication pipeline (`scripts/build_ai_pqc_pdf.mjs` -> `scripts/build_playbook_pdfs.mjs`), adding a transmission publication (`GN-PUB-TXPHY-001`, v1.0.0). The AI/PQC publication rebuilt at an **identical 151 pages**, confirming the refactor is output-preserving; its byte size grew by the `CONVENTIONS.md` Section 5/Section 8.1 edits it carries as a source. The new `GreyNOC_Transmission_Physical_Layer_Playbooks.pdf` is 39 pages with 80 outline entries.
6. Logged residual gaps in Section 5 above rather than implying the medium is now fully covered.

7. Addendum - the track extended below the medium (TX-03)

This audit scoped *transmission media*. A subsequent review found the adjacent gap that scoping missed: the library had no coverage of the **silicon in which the post-quantum algorithms actually execute** - the layer below every medium, where a key is a voltage rather than an integer.

`TX-03` closes it, and carries two findings that change positions taken elsewhere in the library:

- **A FIPS 140-3 validated ML-KEM module carries no side-channel assurance.** FIPS 140-3 introduced a "non-invasive security" requirement area; CMVP never populated it. SP 800-140F approves no test metrics, its Revision 1 draft was never finalized, and the Implementation Guidance's Section 8 and Annex F are empty. Any procurement or vendor-assurance artifact (PB-27) that treats FIPS validation as evidence of physical resistance is overstating it.
- **The most damaging published break of a NIST PQC implementation was caused by a compiler and is network-reachable** (CVE-2024-37880, CVSS 7.5, AV:N). Constant-time source, variable-time binary. This makes "verify the binary, not the source" a build-pipeline control rather than a research curiosity.

TX-03 also settles the **physical floor** of the track: Planck-scale intrusion is not an attack surface, the claim is recorded as a fabrication indicator rather than a threat, and the reproducible negative search behind that conclusion is published with it. That question is now closed and should not be re-litigated.

TX-03 introduces an evidence-grading convention (`[hw]` / `[sim]` / `[norm]` / `[adv]` / `[relayed]` / `[vendor]`) now recorded in `CONVENTIONS.md` Section 8.1. The residual gaps in Section 5 above are unaffected - TX-03 covers a different axis (depth), not the media still missing.

GreyNOC - detection-engineering-first. Reproducible or it didn't happen.

SOURCE: TX-01-rf-spectrum-intrusion.md

TX-01 - RF & Radio-Spectrum Intrusion Detection & Response

TX-01 - RF & Radio-Spectrum Intrusion Detection & Response

1. Overview

Every control in a modern security program assumes the adversary arrives over a wire. Radio does not require one. An RF adversary needs proximity and an antenna - not a credential, not a port, not an egress path through the proxy. The traffic never appears in NetFlow because it never enters the network the SOC instruments.

This playbook covers detection and response for intrusions carried over radio-frequency media, roughly 3 kHz to 300 GHz: Wi-Fi, Bluetooth/BLE, cellular, GNSS reception, sub-GHz ISM and LPWAN, and microwave/satellite backhaul. It also scopes electromagnetic emanation (TEMPEST) honestly - including the parts an ordinary enterprise cannot detect.

The organizing insight is the same one that drives D&R-08 *Malware Beaconing*: **detection runs on geometry, not payload**. Most RF attack traffic is encrypted, proprietary, or deliberately malformed. What gives it away is where it comes from, how strong it is, how it behaves over time, and whether its claimed identity matches its physical position.

The second organizing insight is harder to accept: **passive reception is undetectable in principle**. A receiver emits nothing. An adversary capturing your Wi-Fi, your BLE advertisements, or your microwave backhaul leaves no signal to detect - ever, at any budget. Detection covers *active* RF intrusion; passive interception is addressed by making the capture worthless, which is a cryptographic control, not a detection one. Any RF playbook that claims otherwise is selling something.

Related: TX-02 (optical media, the other half of the physical layer), D&R-17 (exfiltration - RF is an alternate medium, not just an alternate protocol), D&R-15 (persistence - an RF implant is a persistence mechanism), PB-02 (HNDL - passively captured RF is harvested ciphertext).

2. Scope and the RF-BOM

Detection begins with knowing what is *supposed* to be transmitting. The library already builds a CBOM (PB-01) and an AI-BOM (PB-21); the RF equivalent is the same discipline applied to the spectrum plane. Without it there is no baseline, and without a baseline every RF alert is unfalsifiable.

Record, per emitter and per receiver:

- **Identity** - asset ID, owner, physical location (building/floor/room, and outdoor position for fixed links), business purpose.
- **Radio** - band(s), channel/ARFCN/EARFCN plan, modulation, protocol and version, transmit power, antenna type/gain/polarization/azimuth, duty cycle.
- **Addressing** - BSSID/MAC, BLE address type (public, random static, resolvable private), cell identity, LoRaWAN DevEUI/JoinEUI, device serial.
- **Security posture** - authentication and encryption in use (WPA2-PSK, WPA3-SAE, 802.1X, BLE pairing mode, LoRaWAN join method), management-frame protection status, firmware version, whether keys are per-device or shared.

- **Receive-only assets** - GNSS receivers, telemetry receivers, and anything that consumes radio it does not transmit on. These are the assets most often omitted from inventory and most easily attacked, because *nobody thinks of a receiver as an attack surface*.
- **Expected RF neighborhood** - the transmitters you do not own but always see. Adjacent-tenant APs, the coffee shop below, the operator macro cells. If this is not baselined, every one of them becomes an alert.

An RF-BOM entry with no baseline measurement attached is inventory, not telemetry. Pair each fixed emitter with a recorded reference RSSI at each sensor position, and each receiver with its normal signal-quality range.

3. MITRE ATT&CK Mapping

Technique	ID	Matrix	Tactic
Hardware Additions	T1200	Enterprise	Initial Access
Network Sniffing	T1040	Enterprise	Credential Access, Discovery
Adversary-in-the-Middle	T1557	Enterprise	Collection, Credential Access
Exfiltration Over Other Network Medium	T1011	Enterprise	Exfiltration
Exfiltration Over Other Network Medium: Exfiltration Over Bluetooth	T1011.001	Enterprise	Exfiltration
Exfiltration Over Physical Medium	T1052	Enterprise	Exfiltration
Network Denial of Service	T1498	Enterprise	Impact
Network Boundary Bridging	T1599	Enterprise	Defense Impairment
Wireless Compromise	T0860	ICS	Initial Access
Wireless Sniffing	T0887	ICS	- verify against your ATT&CK version
Adversary-in-the-Middle	T0830	ICS	- verify against your ATT&CK version
Denial of Service	T0814	ICS	Inhibit Response Function

Mapping discipline (CONVENTIONS Section 4). ICS tactic placement differs from Enterprise and both IDs and tactic assignments move between ATT&CK versions. Re-verify every row against the version your platform carries before you tag a detection with it.

Deliberately unmapped. The following have no clean ATT&CK technique, and this playbook says so rather than forcing a tag: **RF jamming as a distinct technique** (T1498 describes network-layer volumetric DoS, not physical-layer denial - the mapping is an analogy, use it with a note), **GNSS spoofing**, **rogue cellular base station / IMSI catcher**, and **electromagnetic emanation capture (TEMPEST)**. Tag these with the internal class from Section 5 and describe the behavior.

4. Detection Strategy - and what each tier can actually see

You cannot detect what you cannot receive. RF detection maturity is a function of hardware, and being honest about the tier you are on is a precondition for trusting an absence of alerts.

Tier 0 - infrastructure-derived. No new hardware. Telemetry from radios you already own: wireless LAN controller and AP logs, client association history and RSSI, retry and PHY-error counters, channel-utilization stats, cellular modem diagnostics on managed endpoints, GNSS receiver status sentences, LoRaWAN network-server join logs. This detects: rogue APs on your own channels, evil twins, association anomalies, most jamming, most GNSS spoofing, and cellular downgrade on *managed* devices. It does **not** detect: transmitters on bands your infrastructure does not tune, RF implants using proprietary sub-GHz protocols, or anything passive.

Tier 1 - dedicated sensing. A WIPS overlay, receive-only SDR sensors, or spectrum analyzers at fixed positions. This adds: wideband unauthorized-emitter discovery, spectral-occupancy baselining, RF implant detection, and direction finding when three or more sensors see the same emitter.

Tier 2 - RF baseline and anomaly program. Continuous spectral occupancy modeling per band, per position, per time-of-day, with drift alerting. This is what turns "there is an unknown signal at 915 MHz" into "there is an unknown signal at 915 MHz that was not here last Tuesday and is strongest near the server room."

The five detectable behaviors. Regardless of tier, active RF intrusion reduces to five shapes:

1. **Presence** - an emitter that should not exist. Detection: identity not in the RF-BOM.
2. **Impersonation** - an emitter claiming an identity that does exist. Detection: the claimed identity and the physical evidence disagree. A BSSID your RF-BOM places on floor 3 cannot legitimately appear at -40 dBm on a floor-8 sensor. **Physical position is the hardest property for an adversary to forge** and should carry the most weight in scoring.
3. **Denial** - energy that prevents reception. Detection: noise floor rises while signal quality falls. The distinguishing feature of jamming versus congestion is that jamming degrades SNR without a corresponding rise in *decodable* traffic.
4. **Injection / replay** - valid-looking frames the legitimate transmitter did not send. Detection: sequence-number discontinuities, duplicate counters, frames arriving with the right identity but the wrong RSSI or timing.
5. **Reception anomaly** - a receiver being fed a lie. Detection: physical implausibility in what the receiver reports (see Section 5.4 for the GNSS case, which is the canonical example).

5. Intrusion Classes and Their Indicators

5.1 Wi-Fi (802.11)

- **Rogue AP on the corporate wire.** An unauthorized AP bridging RF to the internal LAN - the cleanest T1599 Network Boundary Bridging case there is. Indicators: an SSID/BSSID absent from the RF-BOM whose wired-side MAC (or an adjacent MAC in the same OUI block) appears in switch CAM tables; an AP with a consumer OUI on an access port; DHCP leases from an unexpected server.
- **Evil twin.** A rogue transmitting a legitimate SSID. Indicators: correct SSID with a BSSID not in the RF-BOM; correct SSID *and* BSSID but implausible RSSI/position (BSSID spoofing); downgraded security posture (an open or WPA2-PSK twin of an 802.1X network); client roams to a new BSSID with no corresponding RSSI trend.
- **Deauthentication / disassociation flood.** Forced client disconnection, usually as a precursor to evil-twin capture or handshake collection. Indicators: burst of deauth/disassoc frames, mass simultaneous client loss across one AP, reason codes inconsistent with the AP's own logs. 802.11w Protected Management Frames - mandatory under WPA3 - largely closes this; **an estate seeing deauth floods is telling you PMF is not enforced.**
- **Probe-response / known-beacon abuse.** A rogue answering client probe requests for any requested SSID, harvesting clients with stale preferred-network lists. Indicators: one BSSID beacons or responding for an implausible number of distinct SSIDs.

- **Handshake capture for offline cracking.** Passive, therefore **not directly detectable** - detect the deauth that provokes the re-handshake, and defend with WPA3-SAE, which removes the offline-dictionary exposure that makes the capture worth doing.

5.2 Bluetooth / BLE

- Unauthorized BLE peripherals advertising inside secure areas; devices whose address type is public/random-static (trackable) where policy requires resolvable private addresses.
- Peripherals paired to corporate endpoints that are absent from the RF-BOM - a BLE HID device is a keystroke injection surface (T1200).
- Exfiltration over Bluetooth (T1011.001): an endpoint with sustained BLE/BR-EDR throughput to an unenrolled peer, especially outside working hours.
- Tracker-class devices persisting with corporate assets or personnel.

5.3 Cellular (LTE / 5G NR)

Detection here is almost entirely endpoint-side, from managed-device modem diagnostics.

- **Rogue base station / IMSI catcher.** Indicators: an unexpected downgrade to 2G/GSM or to a weaker cipher (including null encryption); serving-cell identity not present in the operator's published or previously observed cell database; a cell with abnormally high signal strength for its claimed location; forced reselection away from a stable serving cell; tracking-area updates at an implausible rate; identity requests for permanent identifiers.
- **5G note.** SUCI concealment removes the plain-IMSI exposure that made classic catchers easy, but a downgrade to LTE or 2G re-opens it. **Detect the downgrade, not the catcher.**
- Cellular-enabled rogue devices as an egress bypass: an internal host that also holds a cellular interface is an unmonitored egress path around every proxy control in D&R-17 .

5.4 GNSS reception - the canonical receiver attack

GNSS receivers accept unauthenticated broadcast from space, with received power low enough that a local transmitter trivially overrides it. Time, not just position, is the target: a spoofed clock breaks Kerberos, TOTP, certificate validity, log correlation, and financial timestamping.

Spoofing indicators:

- All tracked satellites reporting near-identical C/N₀, or C/N₀ abnormally high and uniform - real constellations produce a spread driven by elevation angle.
- Position or time discontinuity without corresponding motion; receiver clock steering at an implausible rate.
- Tracked PRN set inconsistent with the almanac for that time and location.
- Two or more independent receivers at known separation reporting the same position.
- Loss of RAIM/integrity consistency, or a sudden drop in reported dilution of precision that does not match sky visibility.

Defenses to record in the RF-BOM: multi-constellation and multi-frequency reception, RAIM, antenna placement with sky-only view and terrain masking, a disciplined holdover oscillator sized to survive the outage you plan for, and signal authentication where the constellation offers it - Galileo OSNMA is available today; GPS signal-authentication work is still in development, so do not plan a control around it as though it were deployed.

5.5 Sub-GHz ISM and LPWAN (433 / 868 / 915 MHz, LoRa, Zigbee, Z-Wave)

This is where RF implants live, because the bands are lightly monitored, propagate well through building structure, and support cheap long-range links.

- An emitter in the RF-BOM's "unknown" column with a periodic duty cycle - the RF equivalent of beaconing (D&R-08), and analyzed the same way: inter-burst interval regularity is the signal.
- LoRaWAN join anomalies: repeated join requests from a known DevEUI, join-request replay, or a DevEUI joining from an implausible gateway.
- Replay against building-automation, sensor, or access-control radios: identical payloads with stale rolling counters.

5.6 Microwave and satellite backhaul

- Link-budget degradation inconsistent with weather (a jamming or interference signature versus rain fade - see Section 8).
- Received signal present with elevated bit-error rate and no corresponding fade: consistent with interference or an injection attempt.
- Any point-to-point link carrying unencrypted payload is a passive-capture target with a large standoff distance. Treat it as harvested (PB-02).

5.7 Electromagnetic emanation (TEMPEST) - scoped honestly

Unintentional EM radiation from cables, displays, and processors can carry recoverable information. This is a real phenomenon and a real research area.

It is also, for the overwhelming majority of enterprises, not detectable. The adversary is a passive receiver. There is no emission to alert on, no log to correlate, and no commercially routine control that verifies whether capture occurred. Treating TEMPEST as a *detection* problem produces theater.

Handle it as an architecture and siting problem instead: zone placement, physical standoff distance, shielding where the threat model genuinely warrants it, and - this being the part that generalizes - **not putting the highest-consequence plaintext processing at the building perimeter**. Escalate to a specialist program only where a documented threat model and a regulatory or classification requirement justifies it. Do not file this under PB-08 C10, which covers computational side channels.

6. Sample Detection Logic (JSON-style)

```
{
  "rule_name": "RF - Evil Twin / SSID Impersonation by Position Implausibility",
  "description": "Detects a BSSID advertising a corporate SSID whose observed physical position or identity contradicts the RF-BOM baseline.",
  "data_source": ["WLC.AP.Neighbor", "WIPS.Sensor.Observation", "RFBOM.Emitter"],
  "logic": {
    "window": "15m",
    "for_each": "observed_emitter",
    "where": { "ssid": "in RFBOM.corporate_ssids" },
    "trigger_any": [
      "bssid not in RFBOM.emitter.bssid",
      "abs(observed.rssi_dbm - RFBOM.baseline_rssi_dbm[sensor_id]) > baseline_tolerance_db",
      "observed.security_profile weaker_than RFBOM.emitter.security_profile",
      "observed.bssid seen_at_sensor not_in RFBOM.emitter.expected_sensors"
    ],
    "escalate_if_any": [
      "observed.security_profile == 'open' or 'wpa2-psk' while baseline == '802.1x'",
      "client_count_migrated_to_observed_bssid >= 3 within 5m",
      "deauth_frame_rate[target_bssid] > baseline_p99 within preceding 10m"
    ]
  },
  "notes": "baseline_tolerance_db MUST be derived per sensor from a recorded local baseline. There is no portable absolute value; RF propagation is site-specific.",
  "severity": "high_when_escalated_else_medium",
  "tags": ["T1557", "T1599", "rf_impersonation"]
}
```

```
{
  "rule_name": "RF - Physical-Layer Denial (Jamming) vs. Congestion",
  "description": "Separates jamming from ordinary congestion by requiring noise-floor rise WITHOUT a matching rise in decodable traffic.",
  "data_source": ["WLC.AP.RadioStats", "WIPS.Spectrum", "AP.ClientAssoc"],
  "logic": {
    "window": "5m",
    "group_by": ["ap_id", "band", "channel"],
    "compute": {
      "noise_delta_dbm": "noise_floor_dbm - baseline_noise_floor_dbm[ap_id, band, hour_of_day]",
      "snr_delta_db": "snr_db - baseline_snr_db[ap_id, band, hour_of_day]",
      "decodable_frame_rate_ratio": "frame_rate / baseline_frame_rate[ap_id, band, hour_of_day]",
      "retry_ratio": "retry_frames / total_frames"
    },
    "having": {
      "noise_delta_dbm_gte": "site_threshold_dbm",
      "snr_delta_db_lte": "-site_threshold_db",
      "decodable_frame_rate_ratio_lte": 1.1,
      "retry_ratio_gte": "site_retry_threshold"
    },
    "escalate_if_any": [
      "affected_ap_count >= 3 and shared_physical_zone == true",
      "concurrent mass_deassociation_event",
      "concurrent alarm on physical_security_system in same zone",
      "band in RFBOM.safety_or_ot_critical_bands"
    ]
  },
  "notes": "Congestion raises noise AND decodable traffic together. Jamming raises noise while decodable traffic stays flat or falls. That divergence is the detection.",
  "severity": "high",
  "tags": ["T1498", "T0814", "rf_denial"]
}
```

```
{
  "rule_name": "RF - GNSS Spoofing by Physical Implausibility",
  "description": "Detects GNSS spoofing from internal inconsistency in receiver telemetry and disagreement between independent receivers.",
  "data_source": ["GNSS.Receiver.Status", "NTP.Peer.Stats", "Asset.Inventory"],
  "logic": {
    "window": "10m",
    "for_each": "gnss_receiver",
    "trigger_any": [
      "stddev(cn0_per_sv_dbhz) < uniformity_threshold and tracked_sv_count >= 6",
      "mean(cn0_per_sv_dbhz) > baseline_p99_cn0[receiver_id]",
      "abs(position_delta_m) > position_tolerance_m and asset.is_stationary == true",
      "abs(clock_offset_delta_s) > time_tolerance_s within window",
      "tracked_prn_set not_consistent_with almanac(time, location)",
      "disagreement_m(receiver_a, receiver_b) < known_separation_m * 0.5"
    ],
    "escalate_if_any": [
      "receiver feeds stratum-1 NTP or PTP grandmaster",
      "dependent_service in ['kerberos_kdc', 'pki_issuance', 'otp_validation', 'trading_timestamp', 'log_pipeline']",
      "two_or_more receivers affected concurrently"
    ],
    "action": "alert + fail_to_holdover_oscillator + freeze_time_dependent_issuance"
  },
  "notes": "Real constellations produce a C/N0 spread driven by elevation angle. A flat, uniformly strong C/N0 profile across all SVs is the classic single-transmitter signature.",
  "severity": "critical_when_escalated_else_high",
  "tags": ["gnss_spoofing", "no_clean_attack_mapping"]
}
```

7. Example Event Data

Documentation MAC addresses per RFC 7042 (00-00-5E-00-53-xx); IPv4 per RFC 5737.

```
WIPS sensor observation - evil twin
ts=2026-08-09T14:22:07Z sensor=SNS-08-N ssid="CORP-SECURE" bssid=00:00:5E:00:53:2F
  rssi=-38 channel=44 security=OPEN rfbom_match=NONE
ts=2026-08-09T14:22:07Z sensor=SNS-08-N ssid="CORP-SECURE" bssid=00:00:5E:00:53:11
```

```

rssi=-71 channel=44 security=WPA3-802.1X rfbom_match=AP-0803 (baseline rssi -69 ±4)

-> Legitimate AP-0803 observed at baseline. Unknown BSSID at +33 dB stronger, security downgraded
to OPEN. Three clients migrated within 4m.

WLC radio stats - denial vs. congestion
ap=AP-0311 band=2.4 ch=6 noise=-92dBm snr=31 frames/s=1840 retry=6% <- baseline
ap=AP-0311 band=2.4 ch=6 noise=-61dBm snr=4 frames/s=1795 retry=71% <- noise +31 dB,
                                                                    traffic flat: denial
ap=AP-0312 band=2.4 ch=6 noise=-63dBm snr=5 frames/s=1602 retry=68% <- same zone
ap=AP-0313 band=2.4 ch=6 noise=-60dBm snr=3 frames/s=1711 retry=74% <- same zone

GNSS receiver status - spoofing
receiver=GNSS-DC1-A fix=3D sv_tracked=11
  cn0_dbhz=[51,51,52,51,51,52,51,51,52,51] stddev=0.45 <- implausibly uniform
  pos_delta_m=0.4 clock_offset_delta_s=+41.7 <- 41s time jump, no motion
receiver=GNSS-DC1-B (separation 84 m) reported_separation_m=3.1 <- both receivers pulled together

Cellular modem diagnostic - managed endpoint
imei=<redacted> rat=LTE cell_id=0x1A2B3C cipher=EEA2 ->
imei=<redacted> rat=GSM cell_id=0x00FF01 cipher=A5/0 rxlev=-42
-> Forced downgrade LTE->GSM with null encryption, serving cell not in observed-cell history,
signal implausibly strong for claimed macro position.

Sub-GHz spectrum sensor - implant beacon
freq=915.4MHz bw=125kHz burst_len=87ms interval=300.02s (cv=0.0007) rfbom_match=NONE
strongest_sensor=SNS-DC-02 (server room) est_position=(rack row C)

```

8. Investigation Steps

1. **Do not transmit.** Investigation is receive-only. Transmitting to probe, deauthenticate, or "test" a suspected rogue is at best evidence contamination and at worst unlawful - see Section 10 for the legal constraint. Every step below is passive unless the engagement authorization says otherwise in writing.
2. **Confirm the observation is real before it is an incident.** Check the sensor itself: calibration date, firmware, antenna condition, and whether a neighbouring sensor corroborates. A single sensor reporting an anomaly no other sensor sees is a sensor fault until proven otherwise.
3. **Reconcile against the RF-BOM.** Is the emitter genuinely unknown, or is it a known asset that was moved, re-flashed, or re-channelized by a change nobody logged? Pull the change record. In practice this resolves the clear majority of "rogue emitter" alerts.
4. **Establish physical position.** With three or more sensors, trilaterate from RSSI; with a directional antenna, bearing-and-walk. Position is the property the adversary cannot forge and the one that converts an alert into an action. Record the method and the uncertainty.
5. **Determine wired-side reachability.** For a suspected rogue AP, search switch CAM tables and DHCP leases for the device MAC and its OUI neighbours. An RF rogue that also touches the wire is a T1599 boundary bridge and escalates immediately.
6. **Characterize behavior over time.** Duty cycle, burst interval and its coefficient of variation, bandwidth, modulation family. Apply the D&R-08 periodicity analysis unchanged - an RF implant beacons for the same reason an implant on a host does.
7. **Identify the affected receivers, not just the emitter.** For denial and spoofing, the consequence is at the receiver. Enumerate what depends on the affected link or timing source before deciding severity: a jammed guest SSID and a jammed OT safety radio are not the same incident.
8. **Scope the compromise reachable through the RF path.** If an evil twin or rogue AP was available, treat every credential and session that transited it as exposed and hand off to D&R-01 / D&R-04 for the identity workstream and D&R-13 for lateral movement.
9. **Preserve evidence properly.** Timestamped I/Q captures where available, sensor observation logs, photographs and chain-of-custody for any recovered hardware, and the RF-BOM state at the time of

detection. Physical devices go to the physical-evidence process - bag it, log it, do not power it on to "see what it is."

10. **Coordinate with physical security and facilities from the start.** RF incidents resolve in the physical world. Badge logs, camera footage, visitor records, and contractor schedules for the affected zone and time window are primary evidence here, not a nice-to-have.

9. False Positive Considerations

RF has the highest ambient false-positive rate of any medium in this library. Most of it is physics, not adversaries.

- **The neighbours.** Adjacent tenants, nearby residences, and passing vehicles produce a constant churn of unknown emitters. Without a baselined RF neighborhood, this alone will bury the queue.
- **2.4 GHz is a junkyard.** Microwave ovens, video senders, cordless phones, wireless cameras, and Bluetooth all share it. A noise-floor spike at lunchtime near a break room is an oven.
- **Multipath and body attenuation.** RSSI swings of 10 dB or more from a door opening, a rack being moved, or a room filling with people are routine. Position estimates carry real uncertainty; treat trilateration as a region, not a point.
- **Legitimate device churn.** Personal hotspots, BYOD, contractor equipment, demo gear, and IoT devices arriving through procurement paths that never touch IT.
- **Weather on outdoor links.** Rain fade on microwave and satellite links looks like degradation. It is distinguishable: fade attenuates the *carrier* (received level drops with error rate rising in proportion), while interference and jamming raise the *noise* with received level steady. Correlate with local weather data before escalating.
- **GNSS ionospheric and multipath effects.** Solar activity, urban canyons, and reflective surfaces degrade fixes without an adversary. The uniform-C/N₀ and independent-receiver-agreement tests exist precisely because they separate natural degradation from a single spoofing transmitter.
- **Maintenance windows.** AP firmware upgrades, channel-plan changes, antenna work, and building-automation commissioning all generate exactly the signatures above.

10. Tuning Guidance

- **Baseline first, alert second.** No RF rule ships before its site has a recorded baseline per sensor, per band, per hour-of-day. Every threshold in Section 6 is written as a deviation from that baseline for this reason - RF propagation is site-specific and any portable absolute number is wrong somewhere.
- **Weight physical implausibility above identity mismatch.** Identity fields are cheap to forge; position, timing, and signal-quality geometry are not. Scoring that leads with position produces far fewer false positives than scoring that leads with an unknown MAC.
- **Suppress the neighborhood as a maintained layer, not an ingest filter.** Same rule as D&R-08: keep the observations, suppress the alerts, and re-evaluate suppressions on a schedule. An adversary parking in the neighbours' RF space is a known tactic.
- **Require corroboration for single-sensor detections** in dense environments, and prefer multi-sensor concurrence for anything that triggers containment.
- **Tune GNSS uniformity thresholds against your own sky view.** A rooftop antenna with a clean horizon and a receiver in an urban canyon produce very different natural C/N₀ spreads.
- **Re-baseline after every physical change** - new walls, new racks, new APs, new neighbours, seasonal foliage on outdoor links. A stale RF baseline generates false positives indefinitely.

- **Track detection coverage explicitly.** Maintain, per band and per zone, whether you have sensing at all. An empty alert queue for a band you do not receive is not a clean result, and it should not be reported as one.

11. Response Actions

Legal constraint, stated before the actions because it governs them. Deliberate radio interference is unlawful in most jurisdictions - in the United States, 47 U.S.C. Section 333 prohibits willful interference with licensed radio communications, and the FCC prohibits the marketing, sale, and operation of jammers outright. Separately, the FCC has taken enforcement action against operators who used 802.11 deauthentication to block personal hotspots on their own premises. **"Jam the rogue" and "deauth it off the air" are not available responses.** They also destroy evidence and can disable safety-critical radio. Containment here is physical, wired, and policy-based. If your program believes it has an exception, get it in writing from counsel before an incident, not during one.

Immediate

- Preserve first: capture sensor observations, I/Q where available, and the current RF-BOM state before anything changes.
- Contain on the wire, not on the air. For a rogue AP with wired reachability, shut the switchport and quarantine the MAC - this is fully effective and entirely lawful.
- Move affected clients to a different band, channel, or SSID where the medium is contested.
- For GNSS spoofing: fail the affected receivers to holdover, and freeze time-dependent issuance (certificates, tokens, timestamps) until the time source is trusted again. **A wrong clock that is still being trusted does more damage than an outage.**
- Dispatch physical security to the estimated position. RF incidents are resolved by a person walking to a place.
- For OT/safety-critical denial, invoke the process-safety response path immediately and in parallel - do not serialize behind the security investigation.

Short-term

- Recover and forensically handle any physical device found; do not power it on outside a controlled environment.
- Rotate every credential and key that could have transited a compromised RF path, including PSKs for any network the rogue impersonated.
- Enforce 802.11w PMF and WPA3 where deauth abuse was observed - the attack is a configuration finding as much as an incident.
- Add the observed emitter characteristics to the RF-BOM as known-hostile, and hunt for the same signature across every other site.
- Review badge, camera, and visitor records for the zone and window; RF proximity implies physical presence.

Long-term

- Close the sensing gap the incident exposed. If the intrusion was found late or by accident, the finding is the coverage gap, not the emitter.
- Build and maintain the RF-BOM as a governed inventory with named owners, on the same footing as the CBOM (PB-01) and AI-BOM (PB-21).
- Eliminate unauthenticated and unencrypted radio from the estate on a dated plan: WPA3/802.1X for Wi-Fi, authenticated and encrypted LPWAN join, encryption on every point-to-point backhaul link.

- Architect on the assumption that RF is interceptable and jammable: **encrypt above the radio**, and ensure no safety-critical or availability-critical function depends on a single radio path with no wired or inertial fallback.
- Bring GNSS-derived time under the same discipline: multi-constellation, multi-frequency, signal authentication where available, disciplined holdover, and cross-checks against independent time sources.
- Include RF in physical-security zoning decisions - where the highest-consequence processing sits relative to the building perimeter is an RF control (Section 5.7).

12. Escalation Criteria

Escalate to incident when **any** of the following are true:

- A rogue emitter is confirmed to have wired-side reachability into the internal network (T1599) - this is a full intrusion, not an RF finding.
- An evil twin or rogue base station is confirmed **and** any client associated to it.
- GNSS spoofing is confirmed against a receiver feeding a time-dependent security service - KDC, PKI issuance, OTP validation, or the log pipeline that every other detection in this library depends on for correlation.
- Denial affects OT, safety, life-safety, or physical-security radio.
- An unauthorized emitter is localized inside a controlled or restricted zone - proximity implies physical access, which is its own incident regardless of what the radio was doing.
- Any RF implant is physically recovered, at any location.
- RF anomalies correlate in time with a physical-security event (forced door, unescorted visitor, after-hours badge) in the same zone.
- Sustained unexplained emission near a facility processing the organization's highest-consequence data.

13. Analyst Notes Template

```
Incident ID:
Detection Rule / Tier (0|1|2):
Detected At / Detected By (sensor IDs):
Band / Frequency / Channel:
Protocol / Modulation (observed):
Claimed Identity (SSID/BSSID/CellID/DevEUI):
RF-BOM Match:          none | known-asset | known-neighbour | known-hostile
Observed RSSI vs Baseline (per sensor):
Estimated Position / Method / Uncertainty:
Duty Cycle / Burst Interval / CV:
Intrusion Class:        presence | impersonation | denial | injection | reception-anomaly
Wired-Side Reachability: Y/N (switch/port/CAM evidence)
Affected Receivers / Dependent Services:
Clients or Sessions Exposed:
Physical Security Correlation (badge/camera/visitor):
Weather / Environmental Correlation (outdoor & GNSS only):
Evidence Preserved:     I/Q | sensor logs | photos | device (chain-of-custody ref)
Transmission Performed: NONE (record any exception + written authorization)
Containment Actions:    wired | physical | policy (jamming/deauth NOT permitted - §11)
Credentials/Keys Rotated:
Coverage Gap Identified:
Outstanding Risks:
Recommendations:
Analyst:
```

14. Summary

Radio is the medium the SOC does not instrument, and an adversary on it bypasses every network control by never entering the network. Detection is geometric: presence, impersonation, denial, injection, and reception anomaly - scored with **physical position weighted above claimed identity**, because position is the one property an adversary cannot forge. Every threshold is a deviation from a locally recorded baseline; there are no portable absolute numbers in RF.

Two limits are structural and must be stated in any report built on this playbook. **Passive interception is undetectable in principle** - it is answered by encrypting above the radio, not by sensing. And **detection is bounded by the bands you actually receive** - an empty alert queue for an uninstrumented band is a coverage gap, not a clean result. Say which tier you are on.

Containment is physical, wired, and policy-based. Jamming and deauthentication are unlawful in most jurisdictions, destroy evidence, and can disable safety-critical radio. Shut the port, walk to the position, and rotate what was exposed.

GreyNOC - detection-engineering-first security operations.

SOURCE: TX-02-optical-nm-data-transmission-intrusion.md

TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling

TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling

1. Overview

Almost every byte the organization owns crosses a nanometer-wavelength carrier at some point. The data-center fabric, the campus backbone, the metro and long-haul links, the subsea cable, the inter-satellite crosslink - all of it is infrared light in glass or in vacuum, at wavelengths between roughly 800 and 1600 nm. It is the highest-bandwidth, longest-lived, least-monitored transmission medium in the estate, and in most organizations nobody in security has ever looked at it.

This playbook covers how data is **created on** and **recovered from** an optical carrier, and how to detect and respond to intrusions against that carrier.

Why this is a post-quantum problem, not just a plumbing problem. PB-02 treats harvest-now-decrypt-later as the dominant risk to long-lived confidentiality. A passive fiber tap is the single best harvesting position that exists. It sits upstream of every application control, it sees aggregate traffic rather than one session, it is silent, and - this is the part that matters - the ciphertext it collects stays collected. An adversary who taps a link in 2026 and stores the output is making a bet about 2036. The optical layer is where the HNDL adversary actually stands.

The two facts that structure everything below:

- 1. A tap costs light.** Extracting a copy of an optical signal removes optical power from the original. It is physics, and it cannot be engineered away - only made small. Modern taps can operate at a fraction of a dB, comfortably inside the margin most links run with. That is why detection depends on a *tight local baseline*, not on a published threshold.
- 2. Optical-layer detection is a tripwire, not a control.** Assume a competent tap can be placed below your detection floor. The control that survives that assumption is cryptographic: encrypt before the photons, with hybrid post-quantum key establishment, so a successful tap yields ciphertext with a shelf life longer than the adversary's patience. Section 9 is where the real defense lives. Section 7 and Section 8 tell you when someone tried.

Related: TX-01 (RF media - the other half of the physical layer), PB-02 (HNDL - this is the harvesting mechanism), PB-03 (hybrid TLS/KEM downgrade - what the tapped traffic had better be wrapped in), PB-09 (PQ VPN/IPsec/SSH - the tunnel over the tapped link), PB-25 (key management - what to rotate when a tap is confirmed), D&R-17 (exfiltration - optical is an alternate medium), D&R-19 (incident response).

2. Scope - the nanometer band

Wavelength	Band / name	Typical use	Security relevance
~380-750 nm	Visible	VLC / Li-Fi, status LEDs, displays	Covert channels; unintentional emission
~780-860 nm	Short-wave IR	Multimode short-reach, some FSO, IR remotes	Short-reach DC fabric; sensor injection

Wavelength	Band / name	Typical use	Security relevance
~1260-1360 nm	O-band (1310 nm nominal)	Single-mode short/medium reach, PON upstream	Campus and DC interconnect
~1460-1530 nm	S-band	Some PON, pump/monitoring	Out-of-band monitoring channels
~1530-1565 nm	C-band (1550 nm nominal)	DWDM metro/long-haul, subsea, coherent	The highest-value tap target in the estate
~1565-1625 nm	L-band	DWDM capacity extension, OTDR monitoring	Monitoring channels; out-of-band tap surface

DWDM channel plans follow the ITU-T G.694.1 grid (commonly 100 GHz or 50 GHz spacing, with flexible-grid deployments in newer systems). **The grid is a security fact, not just an engineering one:** a fiber carrying eighty channels can carry an eighty-first that nobody provisioned, and if your monitoring only watches the channels in the service inventory you will not see it.

Out of scope: X-ray and shorter (not a communications medium here), and the RF/microwave bands covered by TX-01.

3. How data is created on an optical carrier

Detection requires knowing which measurement changes when something is wrong, which requires knowing what the chain does. Transmit side:

1. **Framing and FEC.** Client data is framed (Ethernet, OTN) and forward error correction is added. FEC is the reason a link can degrade substantially before a single frame is lost - and therefore the reason **pre-FEC BER, not post-FEC error counts, is the sensitive early indicator**. Post-FEC errors mean the link is already failing; pre-FEC BER moves first.
2. **Electrical-to-optical conversion.** A laser (DFB or tunable) produces the carrier at an assigned wavelength. Direct modulation or an external modulator (Mach-Zehnder) imprints the data.
3. **Modulation format.** Short reach uses intensity modulation - NRZ/OOK, or PAM4 at higher rates - recovered by direct detection. Long reach uses coherent modulation (QPSK, 16QAM, and higher orders) encoding data in amplitude *and* phase across two polarizations, recovered by mixing with a local-oscillator laser. **Coherent links are materially harder to tap usefully:** the tapper needs to recover phase and polarization state, not merely detect power. Record the modulation format per link in the inventory - it changes the threat model.
4. **Multiplexing.** DWDM combines many wavelengths onto one fiber; ROADMs add, drop, and route individual wavelengths at intermediate sites. **The ROADM is the most under-appreciated security device in the network.** It can be configured to copy a wavelength to a monitor port. That is a legitimate operational feature and a perfect lawful-looking wiretap.
5. **Amplification.** EDFAs boost the aggregate signal without regeneration. They also add noise, which is why OSNR degrades along a path, and why an amplifier's gain-control behavior can mask a power loss introduced downstream - an important detection caveat in Section 7.
6. **Launch into the medium.** Single-mode fiber, multimode fiber, or free space (atmosphere or vacuum).

4. How data is recovered from an optical carrier

1. **Reception.** A photodiode (PIN or APD) for direct detection, or a coherent receiver front-end with a local oscillator and digital signal processing for phase-modulated formats.
2. **Recovered measurements** - this is the security telemetry, and the reason the receive side matters more to a detection engineer than the transmit side:

- **Rx optical power (dBm)** - falls when power is removed. The primary tap indicator.
- **OSNR (dB)** - optical signal-to-noise ratio. Falls with added noise or lost signal.
- **Pre-FEC BER** - moves before anything else user-visible does.
- **State of polarization (SOP) and polarization-dependent loss** - a physical disturbance to a fiber changes polarization state fast. **SOP transient monitoring is the most sensitive widely-available indicator of someone physically handling a cable**, and it is the closest thing the optical layer has to a burglar alarm.
- **Chromatic dispersion and differential group delay** compensation values - these track the physical path. A step change means the path changed.
- **Coherent DSP tap coefficients** on modern transponders - the equalizer's view of the channel. A discontinuity is a physical-path event.

1. **Path characterization telemetry** - not per-packet, but per-fiber:

- **OTDR** - launches pulses and maps reflective and loss events by distance. **An OTDR trace is a fingerprint of the physical route.** Diffing today's trace against a stored reference is the single highest-value optical detection available, because it localizes an event to a distance along the cable.
- **Distributed acoustic / vibration sensing (Φ -OTDR)** where deployed - detects digging, handling, and enclosure entry along the cable route.
- **Optical spectrum analysis** - shows which wavelengths are actually present, versus which ones were provisioned.

5. MITRE ATT&CK Mapping

Technique	ID	Matrix	Tactic
Hardware Additions	T1200	Enterprise	Initial Access
Network Sniffing	T1040	Enterprise	Credential Access, Discovery
Adversary-in-the-Middle	T1557	Enterprise	Collection, Credential Access
Supply Chain Compromise: Compromise Hardware Supply Chain	T1195.003	Enterprise	Initial Access
Exfiltration Over Other Network Medium	T1011	Enterprise	Exfiltration
Exfiltration Over Physical Medium	T1052	Enterprise	Exfiltration
Weaken Encryption	T1600	Enterprise	Defense Impairment
Network Denial of Service	T1498	Enterprise	Impact
Network Sniffing	T0842	ICS	- verify against your ATT&CK version
Adversary-in-the-Middle	T0830	ICS	- verify against your ATT&CK version

Mapping discipline (CONVENTIONS Section 4). ICS tactic placement differs from Enterprise, and both IDs and tactic assignments move between ATT&CK versions. Re-verify each row against the version your platform carries.

Deliberately unmapped. Per **CONVENTIONS Section 4**, these have no clean technique and are described rather than tagged: **passive fiber tapping as a distinct technique** (T1040 is the closest analogue but describes network-layer capture, not physical-medium extraction), **rogue-wavelength injection**, **ROADM monitor-port abuse**, **free-space optical beam interception**, and **optical injection into sensors**. Tag these with the Section 6 class name.

6. Intrusion Classes

These are descriptive classes for this playbook. They are deliberately **not** given a defect-class prefix under **CONVENTIONS Section 8.1** - that registry belongs to the bug-bounty catalogs, and a prefix here would invite a triager to read a physical-medium event as an application defect.

6.1 Passive tap - bend coupler

A clip-on coupler bends the fiber past its critical angle, causing a fraction of the light to escape the core where a detector collects it. **Requires physical access to the cable but no cut, no splice, and no service interruption** - it can be applied and removed in minutes, and it is the reason "the link never went down" is not evidence that nothing happened.

Signature: a small step decrease in downstream Rx power; a rapid SOP transient at the moment of application and removal (handling the fiber is unavoidable); often an OTDR loss event at the tap distance. Magnitude depends entirely on the coupler and the operator's skill, and competent application can land inside a link's normal margin. **This is why the baseline must be tight and why SOP transients matter more than the steady-state power delta.**

6.2 Passive tap - splice and splitter

The fiber is cut and a splitter inserted, sending a permanent copy to the adversary. More reliable and higher-fidelity than a bend coupler, and permanent once installed.

Signature: an unavoidable service interruption at insertion (however brief - check for an unexplained link flap or protection switch, then check what the change record says was happening); a persistent step loss; a **new OTDR event at a fixed distance that was not in the reference trace**. The OTDR event is the durable evidence - the outage is a moment, the splice is forever.

6.3 ROADM / monitor-port abuse and optical-layer AiTM

No physical access required at all. An adversary with access to the optical management plane configures a wavelength copy to a monitor port, or routes a channel through a path they control. This is a **configuration** attack against a legitimate feature, and it produces almost no physical signature - the light is copied by design, not by damage.

Signature: unauthorized change to cross-connect, monitor-port, or optical-channel configuration; a wavelength appearing at a degree or port not in the service design; management-plane access outside change control. **Detection here is control-plane detection, not physics detection.** Treat the optical management system as a Tier-0 privileged system with the same rigor as the network management plane - because that is what it is.

6.4 Rogue wavelength / optical injection

An adversary adds an unprovisioned wavelength to a shared fiber, using the organization's own infrastructure as an uncontrolled transport path - a covert channel that never touches a router. On unlit or dark-fiber pairs this can run indefinitely with no service impact whatsoever.

Signature: optical spectrum analysis shows a channel present that is not in the service inventory - the entire detection is *inventory versus reality*; unexplained EDFA gain-control activity as total input power changes; interference on adjacent provisioned channels.

6.5 Free-space optical and laser links

FSO, building-to-building laser links, and inter-satellite optical crosslinks trade the fiber's physical containment for a beam that exists in open space.

- **Off-axis interception.** A tight beam is genuinely hard to intercept, but atmospheric scattering, beam divergence at long range, and pointing jitter all put recoverable energy outside the intended aperture. Interception is passive and **not detectable at the receiver**.
- **Blinding and denial.** A high-power source aimed at the receive aperture saturates or damages it. Signature: receive power spikes or saturates while BER collapses - the inverse of an atmospheric fade, which drops power and error rate together.
- **Transmitter spoofing and beam hijack.** An adversary positioned within the receive cone presents a stronger signal. Signature: a step change in received power with no corresponding change in reported pointing/tracking error; an alignment lock achieved at an unexpected angle.
- **Environmental confound.** Scintillation, fog, rain, and thermal-gradient beam wander degrade FSO constantly. Any FSO detection that is not correlated against environmental data will produce a false positive every foggy morning. For orbital links, add pointing-acquisition-tracking telemetry and ephemeris as the correlation source.

6.6 Visible light, Li-Fi and IR

Short-range optical links in the visible and near-IR bands. The security property that matters: **containment is optical, not cryptographic**. "It doesn't leave the room" fails at windows, doorways, reflective surfaces, and glass partitions. Treat VLC/Li-Fi as a broadcast medium and encrypt it accordingly.

6.7 Optical air-gap covert channels

Both directions, both real, both demonstrated in published academic research:

- **Egress.** Data modulated onto a status LED, a display, a keyboard indicator, or an IR emitter, captured by a camera or photodiode with line of sight. This is T1052/T1011 - an exfiltration path that never touches a network interface, and therefore never appears in D&R-17.
- **Ingress.** Laser or modulated light injected into an optical sensor, camera, or scanner to inject commands or faults. Published research has demonstrated laser injection into MEMS microphones and optical sensors producing attacker-chosen input.

Detection is not primarily a telemetry problem here: it is line-of-sight control, physical siting, covering or disabling non-essential emitters on high-consequence systems, and treating optical sensors on those systems as untrusted input channels.

6.8 Transceiver and hardware supply chain

An optical module is a computer. It has firmware, an I²C management interface, and physical access to the signal before any host-side control sees it. A malicious or modified transceiver can copy traffic, weaken the link, or provide a persistent implant that survives host rebuild - T1195.003 and T1200.

Signature: module vendor/serial/firmware that does not match the procurement record; DDM/DOM telemetry inconsistent with the module's claimed type; unexpected firmware version or an unexplained in-service firmware change; modules sourced outside the approved supply chain. Reconcile module identity against procurement, not against what the module reports about itself - a module that lies about its traffic will lie about its part number.

6.9 Fiber cut and physical denial

The blunt instrument, and still the most common real-world optical incident. Signature: total loss of signal, OTDR event at a specific distance, protection switch.

The security-relevant subtlety: **a cut can be cover**. A brief unexplained outage on a link is the signature of splice-tap insertion (Section 6.2), and a cut that forces traffic onto a protection path may be intended to move traffic onto a route the adversary *has* tapped. Investigate unexplained optical outages as potential precursors, not just as availability events.

7. Detection Strategy

Telemetry tiers - be explicit about which one you are on, because it determines what an absence of alerts means.

- **Tier 0 - transponder and platform telemetry you already have.** Rx/Tx optical power, OSNR, pre-FEC BER, and DDM/DOM per optical module, polled continuously and baselined. Plus optical-management-plane configuration and audit logs, which are what actually catch Section 6.3. Detects: gross taps, splice insertion, rogue-wavelength effects on provisioned channels, ROADM abuse, denial. Does **not** detect: a well-executed bend tap inside margin, or anything passive in free space.
- **Tier 1 - path characterization.** OTDR baselines with scheduled re-trace and automated diff; optical spectrum analysis against the provisioned channel plan; SOP monitoring where the transponder exposes it. This is where Section 6.1 and Section 6.4 become reliably detectable, and where events become *localizable to a distance* - which is what converts an alert into a dispatch.
- **Tier 2 - continuous physical-layer sensing.** Distributed acoustic sensing on critical routes, in-line optical intrusion detection systems, monitored and alarmed cable enclosures, and continuous SOP transient analysis. This is the tier that detects the fiber being *handled*, before and independently of any measurable loss.

The four detection primitives:

1. **Power and quality deviation from a tight local baseline.** Rx power, OSNR, and pre-FEC BER are baselined per link, per direction, with the normal diurnal and seasonal drift modeled. The detection is a **step change** - a discontinuity - not an absolute threshold. Slow drift is aging and temperature; a step is an event.
2. **Path-fingerprint diff.** Today's OTDR trace against the stored reference. A new event, or a changed loss at an existing event, is a physical change to the route. This is the strongest single optical detection because it carries a distance.
3. **Provisioned-versus-observed inventory.** Which wavelengths are lit, which ports are cross-connected, which modules are installed - reconciled against the service design and the procurement record. Section 6.3, Section 6.4, and Section 6.8 are all inventory-reconciliation detections.
4. **Disturbance transients.** SOP transients and DAS events indicate handling. **These fire during the intrusion, not after it** - they are the only optical primitive with a chance of catching the adversary while they are still at the cable.

Two caveats that must appear in any report built on this playbook:

- **Amplifier gain control can mask a loss.** An EDFA in automatic-gain or constant-output mode will partially compensate for power removed upstream, flattening the very step you are watching for. Baseline and alert on the **pre-amplifier** measurement where the platform exposes it, and record amplifier control mode per span in the inventory.
- **A sufficiently careful tap is below the detection floor of Tier 0 and often Tier 1.** State your floor. Do not report "no evidence of tapping" when the accurate statement is "no event above our detection floor of X dB on

this link." The first is a fabrication under the house rule; the second is a finding.

8. Key Indicators

- Step decrease in Rx optical power on one direction of a link with no maintenance record.
- OSNR degradation without a matching change in span loss, weather, or amplifier state.
- Pre-FEC BER step increase while post-FEC traffic remains clean - **the earliest reliable indicator; treat a pre-FEC step as an event even when nothing user-visible has happened.**
- New or changed OTDR event versus the reference trace, especially at a distance that maps to an accessible location: a manhole, a riser, a patch panel, a building entrance, a cross-connect.
- SOP transient bursts on a link with no physical work scheduled - particularly outside working hours or in a location with no legitimate access.
- Brief unexplained link flap or protection switch followed by a persistent small loss increase - the splice-tap signature (Section 6.2).
- A wavelength present on the fiber that is not in the service inventory (Section 6.4).
- Optical cross-connect, monitor-port, or channel-routing change outside change control (Section 6.3).
- Transceiver vendor, serial, part number, or firmware inconsistent with the procurement record; unexplained in-service module firmware change (Section 6.8).
- Patch-panel, cross-connect enclosure, splice-closure, or manhole access without a work order.
- FSO: receive power spike with BER collapse (blinding); step power change with no pointing-error change (spoof); persistent degradation uncorrelated with weather.
- Unlit/dark fiber pairs showing optical activity.
- Any of the above on a link carrying long-shelf-life data - cross-reference the PB-02 HNDL prioritization directly. **The same physical event on a link carrying decade-lived secrets and on a guest-network uplink are not the same severity.**

9. Design Controls - where the actual defense lives

Detection is a tripwire. These controls are what make a successful tap a non-event, and they belong in the architecture before any of Section 7 is deployed.

- **Encrypt before the photons.** No plaintext on any optical span, including "internal" DCI, dark fiber between owned buildings, and anything a carrier calls a private circuit. Layer-2 MACsec (802.1AE), OTN-layer encryption, or Layer-3 IPsec - chosen per span and recorded per span.
- **Make it post-quantum, and specifically make the key establishment post-quantum.** A tapped span is harvested ciphertext (PB-02), so the relevant question is not whether it is encrypted today but whether it stays confidential for the data's full shelf life. Use hybrid key establishment - see CONVENTIONS Section 1 for ML-KEM parameter selection and CONVENTIONS Section 2 for hybrid named groups such as X25519MLKEM768 (0x11EC). **Where a link encryptor's key agreement is classical-only, that is a finding, and it is the finding that matters most in this playbook** - the physics is a tripwire, this is the control. Record it as a CBOM gap under PB-01 and prioritize it by Mosca margin under PB-14.
- **Prefer AES-256 on long-retention spans.** Grover halves symmetric strength; CONVENTIONS Section 1 is the reference.
- **Never carry key material in-band on the span it protects,** and never derive the link key from something the tap can also see.
- **Govern the optical management plane as a Tier-0 privileged system.** Section 6.3 is a configuration attack; MFA, change control, and audit logging on the optical NMS/SDN controller are the control. Alert on cross-

connect and monitor-port changes the same way you alert on domain-admin changes.

- **Physical protection proportional to consequence.** Alarmed and monitored enclosures, tamper- evident seals on patch panels and splice closures, conduit protection at building entrances, and documented route diversity so a cut cannot force traffic onto a single predictable path.
- **Procurement integrity for transceivers.** Approved-vendor sourcing, receiving inspection, serial reconciliation on install, and firmware version control. Treat an optical module as in-scope for supply-chain assurance (PB-27), not as a consumable.
- **On QKD, the GreyNOC position is explicit.** Quantum key distribution operates at this layer and is frequently proposed as the answer to optical tapping. It requires specialized hardware and trusted-node infrastructure, does not authenticate endpoints on its own, and multiple national authorities - NSA among them - do not recommend it for securing national security systems in place of standardized post-quantum cryptography. **PQC per CONVENTIONS Section 1 remains the GreyNOC default.** Where a QKD deployment exists, treat it as an additional optical asset with its own attack surface, not as a replacement for the controls above.

10. Sample Detection Logic (JSON-style)

```
{
  "rule_name": "Optical - Tap Signature by Step Loss and Quality Deviation",
  "description": "Detects the power/quality discontinuity characteristic of an inserted optical tap, distinguished from aging drift by requiring a step change.",
  "data_source": ["Transponder.OpticalPM", "Module.DDM", "NMS.ChangeRecord", "OpticalNMS.Amplifier"],
  "logic": {
    "window": "60m",
    "group_by": ["link_id", "direction"],
    "compute": {
      "rx_power_step_db": "step_change(rx_power_dbm, method='changepoint')",
      "osnr_step_db": "step_change(osnr_db, method='changepoint')",
      "prefec_ber_ratio": "prefec_ber / baseline_prefec_ber[link_id, direction]",
      "drift_rate_db_per_day": "linear_trend(rx_power_dbm, lookback='30d')"
    },
    "having": {
      "rx_power_step_db_lte": "-link_detection_floor_db",
      "step_duration_s_lte": 300,
      "is_step_not_drift": "abs(rx_power_step_db) > 5 * abs(drift_rate_db_per_day)"
    },
    "corroborate_any": [
      "osnr_step_db <= -link_osnr_floor_db",
      "prefec_ber_ratio >= link_prefec_multiplier",
      "sop_transient_count > baseline_p99 within 60m",
      "link_flap or protection_switch within preceding 24h"
    ],
    "suppress_if": [
      "NMS.ChangeRecord.active_maintenance(link_id) == true",
      "amplifier_control_mode in ['AGC', 'constant_output'] and pre_amp_measurement_unavailable == true"
    ]
  },
  "notes": [
    "link_detection_floor_db is derived per link from its own measured noise, NOT from a published constant. Record it; it is what bounds any 'no evidence of tapping' statement.",
    "The suppress_if amplifier clause is a KNOWN BLIND SPOT, not a clean result: AGC masks upstream loss. Route these links to the OTDR rule instead of silently dropping them."
  ],
  "severity": "high",
  "tags": ["T1040", "T1200", "optical_tap", "hdl_capture_point"]
}
```

```
{
  "rule_name": "Optical - OTDR Path Fingerprint Divergence",
  "description": "Differs the current OTDR trace against the stored reference to detect a physical change to the fiber route, localized to a distance.",
  "data_source": ["OTDR.Trace", "OTDR.ReferenceTrace", "Cable.RouteMap", "NMS.ChangeRecord"],
  "logic": {
    "schedule": "continuous_or_scheduled",
    "for_each": "fiber_span",

```

```

"compute": {
  "new_events": "events(current) - events(reference)",
  "changed_events": "events where abs(loss_db_current - loss_db_reference) > event_tolerance_db",
  "event_location_m": "distance_along_span"
},
"trigger_any": [
  "count(new_events) > 0",
  "count(changed_events) > 0",
  "total_span_loss_db - reference_span_loss_db > span_tolerance_db"
],
"enrich": {
  "physical_location": "RouteMap.lookup(event_location_m)",
  "accessibility": "RouteMap.access_class(event_location_m)"
},
"escalate_if_any": [
  "accessibility in ['manhole', 'riser', 'patch_panel', 'building_entrance', 'cross_connect', 'third_party_facility']",
  "no matching NMS.ChangeRecord within +/- 7d",
  "span carries data_class in PB02.hndl_priority_classes"
]
},
"notes": "The reference trace is the control. Re-baseline ONLY after authorized, documented work, and archive the superseded reference
- a re-baseline performed on top of an intrusion permanently destroys the evidence.",
"severity": "critical_when_escalated_else_high",
"tags": ["T1200", "optical_path_change", "no_clean_attack_mapping"]
}

```

```

{
  "rule_name": "Optical - Unprovisioned Wavelength and Cross-Connect Divergence",
  "description": "Reconciles observed optical spectrum and cross-connect state against the service inventory to detect rogue wavelengths
and monitor-port abuse.",
  "data_source": ["OSA.ChannelScan", "OpticalNMS.CrossConnect", "OpticalNMS.AuditLog", "Service.Inventory"],
  "logic": {
    "window": "1h",
    "trigger_any": [
      "observed_channel not in Service.Inventory.provisioned_channels[fiber_id]",
      "observed_channel_power_dbm > noise_threshold on unlit_or_dark_pair",
      "cross_connect_state != Service.Inventory.designed_cross_connect",
      "monitor_port_active and not in Service.Inventory.approved_monitor_ports",
      "wavelength present at degree/port not in service design"
    ],
    "escalate_if_any": [
      "OpticalNMS.AuditLog shows config change outside approved change window",
      "config change by identity without optical-plane authorization",
      "no audit-log entry corresponds to the observed state change",
      "affected channel carries data_class in PB02.hndl_priority_classes"
    ],
    "action": "alert + preserve_config_snapshot + do_not_revert_before_capture"
  },
  "notes": "An unauthorized monitor port with NO corresponding audit entry is worse than one with a bad entry: it implies the management
plane itself is compromised. Escalate to D&R-19 before touching the configuration.",
  "severity": "critical",
  "tags": ["T1557", "T1040", "roadm_monitor_abuse", "no_clean_attack_mapping"]
}

```

```

{
  "rule_name": "Optical - FSO Beam Interference, Blinding or Spoof",
  "description": "Separates hostile optical events on free-space links from atmospheric degradation using the power/BER relationship and
pointing telemetry.",
  "data_source": ["FSO.Terminal.PM", "FSO.PointingTelemetry", "Weather.Local", "Satellite.Ephemeris"],
  "logic": {
    "window": "15m",
    "for_each": "fso_link",
    "compute": {
      "rx_power_delta_db": "rx_power_dbm - baseline_rx_power_dbm[link_id, geometry]",
      "ber_delta": "prefec_ber / baseline_prefec_ber[link_id]",
      "pointing_error_delta": "tracking_error - baseline_tracking_error[link_id]"
    },
    "trigger_any": [
      "rx_power_delta_db > 0 and ber_delta > 1",
      "abs(rx_power_delta_db) > step_threshold_db and abs(pointing_error_delta) < pointing_tolerance",
      "alignment_lock_acquired_at_angle not in expected_geometry"
    ],
    "suppress_if": [

```

```

    "Weather.Local indicates fog/rain/scintillation consistent with observed fade",
    "Satellite.Ephemeris explains geometry change"
  ],
  "notes": "The discriminator: atmospheric fade drops received power AND raises BER together. Blinding RAISES received power while BER collapses. Spoofing changes received power with NO pointing-error change. Weather correlation is mandatory or this rule fires every foggy morning.",
  "severity": "high"
},
"tags": ["T1498", "T1557", "fso_interference", "no_clean_attack_mapping"]
}

```

11. Example Telemetry

IPv4 per RFC 5737; IPv6 per RFC 3849.

```

Transponder optical PM - bend-tap signature (link DCI-A-B, 1550.12 nm, C-band ch.34)
2026-08-09T02:10 rx=-8.42dBm osnr=21.7dB prefec_ber=2.1e-6 sop_transients=0
2026-08-09T02:15 rx=-8.44dBm osnr=21.7dB prefec_ber=2.2e-6 sop_transients=0
2026-08-09T02:41 rx=-8.43dBm osnr=21.6dB prefec_ber=2.1e-6 sop_transients=47 <- handling
2026-08-09T02:42 rx=-8.91dBm osnr=20.9dB prefec_ber=9.7e-6 sop_transients=112 <- step
2026-08-09T02:47 rx=-8.90dBm osnr=20.9dB prefec_ber=9.9e-6 sop_transients=3
2026-08-09T03:00 rx=-8.90dBm osnr=20.9dB prefec_ber=9.8e-6 sop_transients=0 <- new steady state
-> 0.47 dB step in 60s. 30-day drift rate 0.004 dB/day: this is 117x the drift, i.e. a step.
Post-FEC traffic clean throughout. No change record. link_detection_floor_db = 0.25.

```

OTDR trace diff - span MAN-04 (reference 2026-05-14)

event	distance_m	type	loss_dB_ref	loss_dB_now	delta
E1	0.0	connector	0.31	0.32	+0.01
E2	412.6	splice	0.06	0.06	0.00
E3	1187.3	connector	0.28	0.29	+0.01
E4	2043.9	-- ABSENT --	--	0.44	NEW <<<
E5	3990.1	end	--	--	--

RouteMap.lookup(2043.9) = "Manhole MH-17, 3rd & Vine, access_class=street_manhole"

ChangeRecord(+/-7d) = NONE

Optical spectrum analysis - fiber DARK-PAIR-07 (inventory: unlit)

```

1529.55nm -48.1 dBm (noise)
1550.92nm -14.6 dBm <<< channel present on a pair with no provisioned service
1561.42nm -47.9 dBm (noise)

```

Optical NMS audit - monitor-port abuse

```

2026-08-09T01:58Z user=svc-optical-ro action=cross_connect_add
src=deg2/ch34 dst=mon-port-3 result=SUCCESS change_ticket=<none>
-> Read-only service account performed a write. No ticket. Monitor port not in approved list.

```

FSO terminal - blinding vs. fade (link ROOF-N to ROOF-S)

```

baseline rx=-31.2dBm prefec_ber=4e-7 tracking_err=0.8urad weather=clear
2026-08-09T11:02 rx=-38.7dBm prefec_ber=6e-5 tracking_err=0.9urad weather=fog <- fade (both worsen)
2026-08-09T15:40 rx=-19.4dBm prefec_ber=3e-3 tracking_err=0.8urad weather=clear <- BLINDING
                                                                    (power UP, BER UP)

```

Transceiver reconciliation

```

port=Et1/49 reported: vendor=<V> pn=<P> sn=XXA1934 fw=3.2.1
procurement: vendor=<V> pn=<P> sn=XXA1934 fw=3.1.0 (shipped)
-> In-service firmware change with no maintenance record. Module holds pre-encryption signal path.

```

12. Investigation Steps

- 1. Do not re-baseline, do not revert, do not clean the connector.** The reference OTDR trace, the current optical PM history, and the current cross-connect configuration are the evidence. A re-baseline performed on top of an intrusion destroys it permanently and irreversibly. Snapshot everything before any remediation touches the link.
- 2. Check the change record first.** Optical events have mundane causes at a high rate: maintenance, connector cleaning, re-patching, splice repair, module replacement, construction along the route. Pull work orders,

carrier maintenance notices, and contractor schedules for the link and the window. This resolves most alerts and it resolves them fast.

3. **Confirm the step is a step.** Compare the magnitude against the link's own 30-90 day drift rate. Aging, temperature, and connector degradation produce gradual change; a tap produces a discontinuity. Compute the ratio and put it in the report - it is the difference between an event and a maintenance ticket.
4. **Localize with OTDR and map the distance to a physical place.** This is the decisive step. A distance becomes a manhole, a riser, a patch panel, a building entrance, a carrier cross-connect, a colocation cage. Record the access class of that location, because it determines both who could have done it and how urgent the dispatch is.
5. **Correlate with physical access.** Badge logs, camera footage, work orders, visitor records, and carrier or landlord access logs for that location and window. For third-party facilities, this means a formal request - start it immediately; it is the long pole.
6. **Check the direction and the position in the path.** Which direction lost power, and where the loss sits relative to amplifiers, tells you where in the span to look and whether AGC could have masked a larger upstream loss than you measured.
7. **Reconcile the optical inventory end to end.** Provisioned wavelengths versus observed spectrum; designed cross-connects versus running configuration; procurement records versus installed module serials and firmware. Rogue wavelengths, ROADM abuse, and malicious transceivers are all found here and nowhere else.
8. **For any management-plane involvement, pivot to a full intrusion investigation.** An unauthorized cross-connect means someone had access to the optical NMS. That is a compromised privileged system - hand off to D&R-19 and treat the optical event as one symptom, not the incident.
9. **Determine exposure, and determine it cryptographically.** Enumerate every service, tunnel, and data class carried on the affected wavelength for the entire period since the last verified clean baseline - **not since detection**. Then answer the question that actually determines severity: *was the traffic on that span encrypted, with what key establishment, and does its confidentiality need to survive a cryptanalytically relevant quantum computer?* Ciphertext under hybrid PQ key establishment is a contained incident. Plaintext, or ciphertext under classical-only key exchange carrying decade-lived secrets, is an HNDL exposure - scope it under PB-02 and escalate accordingly.
10. **Assume the exposure window is longer than the detection window.** A bend tap leaves nothing behind once removed. The defensible statement is bounded by your last verified clean measurement, and that is the window you must report.
11. **Preserve physical evidence properly.** If a device is found, photograph in place, document chain of custody, and hand to the physical-evidence process. Do not power it on outside a controlled environment.

13. False Positive Considerations

Most optical anomalies are maintenance and physics. Expect this to dominate the queue.

- **Scheduled and unscheduled maintenance** - splice repair, re-patching, module replacement, carrier work on leased spans. Carrier maintenance notices frequently arrive late or not at all; chase them rather than escalating.
- **Connector contamination and cleaning.** A dirty connector adds loss gradually; cleaning it removes loss suddenly. **A sudden loss improvement is a change record you are missing, not a clean result.**
- **Temperature and seasonal drift.** Aerial fiber, building risers, and outside plant all show diurnal and seasonal variation. Model it into the baseline or it will fire daily.

- **Component aging.** Laser output declines over life; receiver sensitivity degrades. Gradual, not step - which is exactly what the step-versus-drift test in Section 10 separates.
- **Amplifier gain transients** during channel add/drop operations, which are legitimate service activity.
- **Protection switching** moving traffic to a path with different loss characteristics. The new path has a different baseline; alerting against the old one is a false positive.
- **Construction and vibration near the route** producing SOP and DAS events with no tap. This is the main SOP false-positive source; correlate with known works.
- **FSO weather** - fog, rain, snow, scintillation, and thermal beam wander. Weather correlation is mandatory for any FSO rule.
- **Orbital-link geometry** - legitimate pointing and handover events on inter-satellite links. Correlate against ephemeris.

14. Tuning Guidance

- **The baseline is the detection.** Nothing in this playbook works without a per-link, per- direction, drift-modeled baseline of Rx power, OSNR, and pre-FEC BER, plus a stored OTDR reference trace per span. Build these before writing a single rule.
- **Record `link_detection_floor_db` per link and treat it as a first-class output**, not an internal parameter. It bounds every statement the program can make about tapping on that link, and it belongs in the analyst notes and in any assurance report.
- **Alert on steps, not thresholds.** Use changepoint detection with the drift-ratio test. Absolute-threshold alerting on optical power produces alarm fatigue and misses small taps.
- **Lead with pre-FEC BER.** It moves before post-FEC errors, before traffic impact, and often before a power step is unambiguous.
- **Prioritize by data class, not by link.** Use the PB-02 HNDL prioritization to decide which spans get Tier-1 and Tier-2 sensing. Not every fiber warrants an OTDR program; the ones carrying decade-lived confidentiality do.
- **Re-baseline only after authorized documented work, and archive the superseded reference.** Never let an automated process silently re-baseline.
- **Treat AGC-masked links as an explicit coverage gap** with a named owner and a compensating control (OTDR or SOP), not as links that simply never alert.
- **Reconcile inventory on a schedule, not only on alert.** Rogue wavelengths and unauthorized cross-connects are found by periodic reconciliation; a rogue λ on a dark pair generates no service impact and will never alert on its own.

15. Response Actions

Immediate

- Preserve before you fix: snapshot optical PM history, current and reference OTDR traces, spectrum scan, cross-connect configuration, module inventory, and NMS audit logs. **Remediation destroys optical evidence - capture first, without exception.**
- Do not revert an unauthorized cross-connect before capturing it; the configuration is the evidence and reverting may tip the adversary.
- Determine what the affected wavelength carries and how it is protected. This determines everything downstream.

- Dispatch to the localized physical position; engage facilities, the carrier, or the colocation provider as the location requires.
- If safe and available, move critical traffic to a diverse path - but confirm the alternate path is not the one the adversary intended to force you onto (Section 6.9).
- For confirmed management-plane compromise, invoke **D&R-19** and treat the optical NMS as a compromised privileged system.

Short-term

- **Rotate keys on the assumption the tap succeeded.** Every link encryptor key, every session key negotiated over the affected span, and every long-lived secret that transited it since the last verified clean baseline. **PB-25** governs the rotation and rewrap workflow.
- Where key establishment on the affected span was classical-only, **treat all traffic carried since the last clean baseline as harvested** and scope it under **PB-02**. This is the HNDL case made concrete: the ciphertext is gone, and its confidentiality now depends entirely on the key exchange that protected it.
- Re-verify the physical path end to end, including patch panels, cross-connects, splice closures, and any third-party facility on the route.
- Reconcile every transceiver on the affected path against procurement; replace anything that does not reconcile.
- Sweep for the same signature across every other span - a tap found on one link is a reason to re-trace the rest, and organizations routinely find the second one this way.
- Notify the carrier or facility provider where the event localizes to their infrastructure, and preserve the right to inspect.

Long-term

- Close the encryption gap the incident exposed. **Any span found carrying plaintext or classical-only key establishment is the primary finding of the incident**, regardless of whether the tap is confirmed - the tap is the demonstration, the gap is the vulnerability. Migrate to hybrid PQ key establishment per **CONVENTIONS Section 1/Section 2**, and record it in the CBOM (**PB-01**) with a Mosca-margin-driven date (**PB-14**).
- Raise sensing tier on spans carrying HNDL-priority data: OTDR baselining with automated diff at minimum, DAS on critical routes where the consequence justifies it.
- Bring the optical management plane fully under privileged-access management with alerting on cross-connect and monitor-port changes.
- Harden the physical route: alarmed enclosures, tamper-evident seals, conduit protection, and documented, genuinely diverse routing.
- Add optical modules to supply-chain assurance (**PB-27**) with serial reconciliation at install.
- Add the optical plane to the CBOM as a first-class transport surface, so the next crypto inventory does not stop at the application layer.

16. Escalation Criteria

Escalate to incident when **any** of the following are true:

- An OTDR event appears that is absent from the reference trace with no corresponding change record - regardless of magnitude.
- A step power or OSNR loss is confirmed as a step (not drift) with no maintenance explanation.
- An unprovisioned wavelength is observed on any fiber, lit or dark.

- Any unauthorized optical cross-connect or monitor-port configuration is found - and treat it as **critical** where no corresponding audit-log entry exists, because that implies the management plane itself is compromised.
- A transceiver fails procurement reconciliation on serial or firmware.
- The affected span carried **plaintext**, or ciphertext under **classical-only key establishment**, and the data class has a shelf life extending past the organization's quantum risk horizon. This is an HNDL exposure under PB-02 and escalates on its own merits, whether or not the tap is ever confirmed.
- SOP or DAS disturbance events occur at a location with no authorized access, particularly out-of-hours.
- FSO blinding or spoofing signature confirmed against weather and ephemeris.
- An optical event correlates with a physical-security event on the same route.
- An unexplained optical outage occurs on a link carrying high-consequence data - investigate as a possible splice-tap insertion or path-forcing precursor (Section 6.9), not as an availability ticket.

17. Analyst Notes Template

```

Incident ID:
Detection Rule / Telemetry Tier (0|1|2):
Detected At / Detected By:
Link / Span ID / Direction:
Wavelength (nm) / DWDM Channel / Modulation Format:
Medium:          SMF | MMF | FSO | ISL | VLC/IR
Intrusion Class:  bend-tap | splice-tap | ROADM/monitor | rogue-lambda | FSO |
                  air-gap-optical | transceiver-supply-chain | physical-denial

--- Measurements ---
Rx Power: baseline ____ dBm  observed ____ dBm  step ____ dB
OSNR:      baseline ____ dB   observed ____ dB
Pre-FEC BER: baseline ____   observed ____   ratio ____
30-90d drift rate ____ dB/day  step:drift ratio ____ (step confirmed? Y/N)
link_detection_floor_db: ____  <-- BOUNDS EVERY "no evidence" STATEMENT IN THIS REPORT
SOP transients / DAS events: ____
Amplifier control mode / AGC masking possible: ____ / Y/N

--- Localization ---
OTDR reference date / new or changed event / distance: ____ / ____ / ____ m
Physical location / access class: ____ / ____
Third-party facility involved: ____
Physical access correlation (badge/camera/work order/carrier): ____
Weather / ephemeris correlation (FSO & ISL only): ____

--- Inventory reconciliation ---
Provisioned vs observed wavelengths: ____
Cross-connect design vs running: ____
Monitor ports (approved vs active): ____
Transceiver serial/firmware vs procurement: ____
NMS audit entry present for observed change: Y/N  <-- N = management-plane compromise

--- Exposure ---
Services / data classes on affected wavelength: ____
Encryption in force on span: none | MACsec | OTN | IPsec | ____
Key establishment: classical-only | hybrid PQ (____)  <-- THE severity determinant
Data shelf life vs quantum risk horizon (PB-14 Mosca): ____
Last verified clean baseline: ____  Exposure window: ____
HNDL scoping required (PB-02): Y/N

--- Handling ---
Evidence preserved before remediation: Y/N (list)
Keys rotated / rewrap scope (PB-25): ____
Containment actions:
Coverage gap identified:
Outstanding Risks:
Recommendations:
Analyst:

```

18. Summary

Data is created at the nanometer scale by imprinting bits on a laser carrier - intensity-modulated for short reach, coherent phase-and-polarization modulated for long reach - multiplexed onto a DWDM grid, amplified, and routed through ROADMs. It is recovered by a photodiode or a coherent receiver whose telemetry - Rx power, OSNR, pre-FEC BER, state of polarization - is the security instrumentation for the medium.

Intrusion detection rests on four primitives: **step deviation** from a tight local baseline, **OTDR path-fingerprint diff** (the only primitive that yields a distance, and therefore a dispatch), **provisioned-versus-observed inventory reconciliation** (which is how rogue wavelengths, ROADM monitor abuse, and malicious transceivers are found), and **disturbance transients** (the only primitive that fires while the adversary is still at the cable). Alert on steps rather than thresholds, lead with pre-FEC BER, and preserve the reference trace as evidence - a re-baseline over an intrusion erases it permanently.

Two limits must be stated in every report. **Amplifier gain control can mask upstream loss** - such links are a named coverage gap, not quiet links. And **a competent tap can sit below the detection floor**, so the honest finding is "no event above our floor of X dB," never "no evidence of tapping."

Which is why the response is cryptographic before it is physical. Assume the tap succeeded: rotate keys, scope the exposure from the last verified clean baseline rather than from detection, and treat any span running plaintext or classical-only key establishment as the primary finding. Optical monitoring tells you someone was at the cable. **Hybrid post-quantum key establishment is what makes it not matter.**

GreyNOC - detection-engineering-first security operations.

SOURCE: TX-03-pq-nanometer-silicon-physical-attack.md

TX-03 - Post-Quantum Cryptography at the Nanometer Scale: Silicon, Physical Attack & the Physics Floor

TX-03 - Post-Quantum Cryptography at the Nanometer Scale: Silicon, Physical Attack & the Physics Floor

1. Overview

TX-01 covers the radio medium. TX-02 covers the optical medium. This playbook goes *below* the medium, into the silicon where ML-KEM and ML-DSA actually execute - where a key is not an abstract integer but a voltage on a wire, a charge in a cell, and a pattern of switching current that radiates.

The organizing fact is this: **the post-quantum migration replaced algorithms whose implementation security had twenty-five years of attack literature behind it with algorithms whose implementation security is being written right now.** The mathematics of ML-KEM and ML-DSA is the most scrutinized part of the transition. The silicon is the least. Every published attack in Section 7-Section 9 targets a *correct* implementation of a *standardized* algorithm - none of them break the lattice problem, and none of them care whether a quantum computer exists.

Three findings drive everything below, and each is verifiable from a primary source:

- 1. The most damaging published break of a NIST PQC implementation to date was caused by a compiler, is reachable over a network, and needed no laboratory.** CVE-2024-37880 (CVSS 7.5, AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N), quoted in full: "The Kyber reference implementation before 9b8d306, when compiled by LLVM Clang through 18.x with some common optimization options, has a timing side channel that allows attackers to recover an ML-KEM 512 secret key in minutes. This occurs because `poly_frommsg` in `poly.c` does not prevent Clang from emitting a vulnerable secret-dependent branch." Constant-time source, non-constant-time binary.
- 2. A FIPS 140-3 validated ML-KEM module carries no side-channel assurance whatsoever.** FIPS 140-3 created a "non-invasive security" requirement area and CMVP has never populated it - SP 800-140F approves no test metrics, and the Implementation Guidance's Section 8 and Annex F are empty. This is a procurement fact with immediate contractual consequences (Section 11).
- 3. There is no Planck-scale attack surface, and the claim that there is one is a fabrication indicator.** Appendix A settles this with numbers rather than assertion, because the physical floor of this track needed to be documented once, properly, so it never has to be argued again.

Related: TX-01, TX-02 (the media above this layer), PB-01 (CBOM - extend it to silicon), PB-05 (PQ signature and token integrity - this is the layer where those signatures are computed), PB-11 (PQ code signing and firmware - the LMS/XMSS state hazards in Section 10.5 are its physical counterpart), PB-13 (crypto-agility), PB-14 (Mosca margin - drives which keys justify which controls), PB-25 (key management - the rotation path when a device is compromised), PB-27 (vendor assurance - Section 11 is its evidence base), D&R-19 (AI security incident response - the nearest IR twin in the library, but note its evidence and containment steps are AI-specific and do not cover physical-custody incidents).

2. Scope

In scope. Physical and physically-derived attacks against implementations of the post-quantum standards - ML-KEM (FIPS 203), ML-DSA (FIPS 204), SLH-DSA (FIPS 205), FN-DSA/Falcon (FIPS 206, in development), and the stateful hash-based signatures LMS/XMSS (SP 800-208) - across three access tiers: software-reachable (Section 7), bench/laboratory (Section 8), and fabrication/supply chain (Section 9). Plus the assurance regime that is supposed to govern them (Section 11), and the physical limits that bound the whole subject (Appendix A).

Explicitly out of scope. Naming these matters as much as naming what is in, because this subject has unusually porous edges:

1. **Quantum-gravity phenomenology as a threat model.** Any claimed attack requiring physics beyond the Standard Model plus general relativity is out of scope as a threat and retained only as a fabrication indicator (Section 3, Appendix A).
2. **The cryptanalytic quantum threat** - Shor, Grover, HNDL, CRQC timelines. That is PB-02 and PB-14. This playbook is about implementations, not algorithms.
3. **Mathematical cryptanalysis** of the PQC schemes - lattice reduction, MLWE hardness, parameter selection.
4. **The transmission medium** - RF (TX-01), fiber/FSO/ROADM (TX-02). This playbook begins below the medium.
5. **General transient-execution and microarchitectural attacks** - Spectre, Meltdown, MDS, and cache side channels. Hertzbleed, PLATYPUS, Plundervolt and Rowhammer stay **in**, because they are *physical* mechanisms reached from software. The boundary is physics, not privilege.
6. **Non-silicon emanations** - acoustic, thermal-at-range, screen emanation, classical TEMPEST. Route to TX-01 Section 5.7.
7. **Attacks on quantum hardware** - QKD implementation attacks, quantum-computer control planes.
8. **Building or operating attack equipment.** No FIB recipes, laser-rig construction, beamtime procedures, or hammering primitives. Capability is characterized for defense, procurement and risk rating only.
9. **Unauthorized testing.** CONVENTIONS Section 6 ROE binds everything here. Destructive analysis is performed only on assets the operator owns or is contracted to destroy.
10. **Speculative capability with no demonstrated instance** - notably cryptographic key recovery by X-ray or gamma fault injection. No published work demonstrates it; it is recorded as a negative, date-stamped, and not modeled as a live threat.

3. Provenance discipline and fabrication indicators

This subject mixes four unrelated physics regimes and a marketing vocabulary, and the failure mode is not error - it is *plausible* error that survives review. The following rules are normative for any GreyNOC artifact derived from this playbook. They are written to be quoted directly into a report.

Every length carries its provenance: measured, projected, derived, or marketing. A process-node name is a marketing label and is never used as a dimension.

"Quantum" in ML-KEM and ML-DSA denotes an adversary's computational model. No mechanism in this playbook depends on quantum-gravitational physics, and none of the attacks described changes if quantum gravity is or is not real.

A null result is reported as "not observed at the stated sensitivity, with the exclusion bound quoted" - never as "does not exist."

The Planck length is a limit on measurement, not an interface. It bounds what any probe can resolve; it does not describe anything an adversary can address, modulate, or exfiltrate through.

Resolution is not capability. An imaging or beam-spot figure is admissible only alongside the demonstrated outcome it produced, on a named target, with the sample preparation stated.

Every quoted number is labeled measured / simulated / relayed / vendor-stated. Relayed figures are never presented as the citing authors' own measurements. Where a paper attacks a proof-of-concept the authors implemented themselves, the artifact says so in the same sentence as the result.

If a claim's only support is that a number is very small or very large, it is not a claim.

The phrases "Planck-length intrusion", "Planck-scale attack surface" and "sub-Planck side channel" have no referent in information security. Their appearance in a report, finding, or vendor claim triggers a provenance review of the entire document, not a technical investigation.

Evidence grades used throughout. Every attack in Section 7-Section 10 carries one:

Grade	Meaning
[hw]	Demonstrated on real hardware, with the platform named
[sim]	Demonstrated in a leakage model or simulation only - no measured traces
[norm]	Normative standard text ("shall")
[adv]	Advisory standard text ("should", "care must be taken")
[relayed]	The citing authors quote a third party; not their own measurement
[vendor]	Vendor-stated, unaudited
[analysis]	Analytical or formal result - a proof, model, or standards analysis; no implementation demonstrated

An attack at [sim] is never tabulated beside one at [hw] without the grade visible. This single convention prevents most of the overclaiming this field is prone to.

4. The length-scale ladder

Four different physics, one word ("small"). Putting these on a single mental ladder is the most common error in this subject.

Scale	Value	What it is	Provenance
Fiber C-band	1530-1565 nm	The medium of TX-02	measured
Optical probing / LFI	1064-1300 nm	Light that penetrates bulk silicon backside	measured

Scale	Value	What it is	Provenance
Optical prober / LFI spot	~1 μm without SIL; ~200 nm with	What an optical prober resolves - set by objective NA and, for laser fault injection, by the optical path. Not a diffraction floor (Section 8.2)	measured / [re]ayed]
Photon emission band	above ~1 μm	Where silicon is transparent to its own emission	measured
SRAM / BBRAM cell	1.9 $\times$ 2.5 μm to 3.1 $\times$ 2.8 μm	What actually has to be resolved to read a bit	measured
Metal / gate pitch	23-50 nm	Real device dimensions	measured (vendor/analyst)
Node <i>name</i>	"3 nm", "2 nm"	A marketing label. Not a dimension.	marketing
EUV exposure wavelength	13.5 nm	Lithography light	measured
Physical gate length floor	~12 nm	Projected saturation	projected (IRDS roadmap target)
X-ray imaging of ICs	nanometre-class	Non-destructive inspection	measured
Planck length	1.616255(18) $\times 10^{-35}$ m	A limit on measurement	derived constant

Two entries deserve emphasis because both have caused published errors:

- **Node names decoupled from physical dimensions in the mid-1990s.** IEEE Spectrum (Samuel K. Moore, 21 July 2020) quotes Paolo Gargini - IEEE Life Fellow, Intel veteran, IRDS chair - that a node name has "nothing to do with any dimension that you can find on the die"; Intel's 22 nm FinFET generation had a 26 nm gate length, 40 nm half-pitch and 8 nm fin width. Real published pitches: Intel 4's scaled high-performance library offers a 50 nm gate pitch, 30 nm fin pitch and 30 nm minimum metal pitch (VLSI 2022); analyst reporting on TSMC's IEDM 2022 papers gives a 45 nm contacted gate pitch for N3 and a 23 nm minimum metal pitch for N3E. **Dividing an optical spot size by a node name produces a number that means nothing** - a mistake made during the research for this very playbook and caught in adversarial review.
- **IRDS GxxMxx/Tx figures are projected roadmap targets**, not measured pitches. IRDS 2024 projects physical channel length saturating near 12 nm. Cite them as projections.

5. MITRE ATT&CK Mapping

Technique	ID	Matrix	Tactic
Hardware Additions	T1200	Enterprise	Initial Access
Supply Chain Compromise: Compromise Hardware Supply Chain	T1195.003	Enterprise	Initial Access
Weaken Encryption	T1600	Enterprise	Defense Impairment
Unsecured Credentials: Private Keys	T1552.004	Enterprise	Credential Access
Exploitation for Privilege Escalation	T1068	Enterprise	Privilege Escalation
Subvert Trust Controls: Code Signing	T1553.002	Enterprise	Defense Impairment

Technique	ID	Matrix	Tactic
Pre-OS Boot: System Firmware	T1542.001	Enterprise	Persistence, Stealth
Forge Web Credentials	T1606	Enterprise	Credential Access

Mapping discipline (CONVENTIONS Section 4). This table was verified against **ATT&CK Enterprise v19.2**. That version matters: **v19 retired the "Defense Evasion" tactic**, renaming TA0005 to **Stealth** and splitting out **TA0112 Defense Impairment**. Any artifact carrying a "Defense Evasion" tag for T1600, T1553.002 or T1599 is mapped against a pre-v19 collection and must be re-mapped, exactly as CONVENTIONS Section 4 requires for ATLAS. Re-verify against the version your platform carries.

Deliberately unmapped. Per CONVENTIONS Section 4, these have no clean technique and are described rather than tagged: **side-channel key extraction** (power/EM/timing/photonic - T1552.004 covers the *outcome*, not the mechanism), **fault injection**, **Rowhammer**, **optical probing**, **dopant- or analog-level hardware trojans**, **malicious key generation**, and **hardware key-store extraction** (T1555 Credentials from Password Stores describes *software* credential stores and does not cover pulling a key out of an HSM or secure element - it is deliberately not tagged here). Tag these with the descriptive class name in the heading of the Section 7-Section 9 subsection they belong to (for example *compiler-emitted branch*, *Rowhammer fault delivery*, *optical probing*, *malicious key generation*) and describe the mechanism. These classes are deliberately **not** given a defect-class prefix under CONVENTIONS Section 8.1 - that registry belongs to the bug-bounty catalogs, and a prefix here would invite a triager to read a silicon-level event as an application defect.

6. Attack tiers - and what each actually yields a defender

Actionability collapses sharply as physical access increases. Being explicit about this is what separates a usable playbook from a literature review.

Tier	Access required	Runtime detection?	What a defender actually gets
A - Software-reachable (Section 7)	Unprivileged or privileged code on the target; sometimes only network	Yes - patchable, testable, telemetry exists	Nearly all deployable controls live here
B - Bench / laboratory (Section 8)	Unattended physical possession of the device	No	Design-time and procurement requirements only
C - Fabrication / supply chain (Section 9)	Access to design, mask, fab, or distribution	No (post-fab detection is inspection, not monitoring)	Provenance, inspection sampling, procurement

Say the quiet part in every report built on this playbook: for Tier B and Tier C there is *no runtime detection*. The compensating control is blast-radius reduction - per-device keys, short validity, no global signing key resident on a fielded device, revocation that functions, and attestation that fails closed. If a report implies a SOC can detect an optical probing attack in progress, it is wrong.

7. Tier A - software-reachable physical attacks

No laboratory. No physical possession. This is where the CVEs are.

7.1 Compiler-induced timing leakage - the defining defect class

KyberSlash. [hw] Two timing vulnerabilities exploiting secret-dependent division timings in several Kyber/ML-KEM implementations *including the official reference code*, demonstrated on Raspberry Pi 2 (Arm Cortex-A7) and Arm Cortex-M4. Kyber secret keys were "reliably recovered within minutes for KyberSlash2 and a few hours for KyberSlash1" (Bernstein et al., TCHES 2025).

Clangover / CVE-2024-37880 is a **separate defect from KyberSlash**, and the record that should change procurement language: the Kyber reference implementation before commit 9b8d306, **when compiled by LLVM Clang through 18.x with some common optimization options**, has a timing side channel allowing recovery of an ML-KEM-512 secret key in minutes - "because `poly_frommsg` in `poly.c` does not prevent Clang from emitting a vulnerable secret-dependent branch." CVSS 7.5, vector `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`.

Keep the two straight, because they patch separately. KyberSlash is a *source-level* defect - secret-dependent **division** - fixed by library patches. Clangover is a *compiler-emitted branch* in `poly_frommsg`, fixed by commit 9b8d306, which replaced the vulnerable construct so Clang could no longer lower it to a branch. **A KyberSlash-patched library is not necessarily past 9b8d306**. Verify both.

Three properties make this the most important single entry in the playbook:

- **NVD scored it `AV:N/PR:N/UI:N`** [relayed - an NVD scoring judgement, not a demonstrated remote exploit]. The published proof of concept is a *local* attack using end-to-end decapsulation timing; no network-side demonstration has been published. Both facts belong in a report - the rating drives triage, the demonstration drives realism.
- **It recovers the long-term secret key**, not a session key.
- **The source was constant-time; the compiler was not.** Reviewing source code would not have found it. This is the property that makes it a build-pipeline problem rather than a coding one.

The control follows directly: verify the binary, not the source. The KyberSlash authors patched Valgrind to detect variable-time instructions operating on secret data and ran it across more than 1,000 cryptographic primitive implementations in SUPERCOP, reporting multiple findings. That is a reproducible method a defender can adopt.

7.2 Rowhammer as a fault-injection delivery vehicle

Rowhammer converts "physical fault injection" from a lab capability into a software one, and two published attacks turn it directly into PQC key compromise.

Phoenix (CVE-2025-6202). [hw] "Vulnerability in SK Hynix DDR5 on x86 allows a local attacker to trigger Rowhammer bit flips impacting the Hardware Integrity and the system's security. This issue affects DDR5: DIMMs produced from 2021-1 until 2024-12." CVSS 4.0 base 7.1, `AV:L/AC:H/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:H/SI:H/SA:H`. The research team reports **all 15 SK Hynix DDR5 DIMMs tested were vulnerable** to one of two patterns, average time to privilege escalation 5 min 19 s (fastest 109 s).

On-die ECC does not save you, and the reason is worth understanding. The researchers state bit flips "accumulate over time as ODECC only corrects bits after writing data or after a certain time (e.g., every 24 hours)." Treating DDR5 on-die ECC as a Rowhammer mitigation is a documented error.

Mitigation with a measured cost: tripling the refresh rate ($t_{REFI} \sim 1.3 \mu s$) stops the attack at an overhead of 8.4% running SPEC CPU2017.

Crowhammer against FN-DSA/Falcon. [analysis] A *single* targeted bit flip in Falcon's hardcoded reverse cumulative distribution table (RCDT) for the base Gaussian sampler suffices for full signing-key recovery, given on the order of a few hundred million signatures; more flips reduce the signature requirement (CRYPTO 2025). **Grade this honestly:** the paper is a cryptanalytic result that *proves the resulting distribution is skewed enough to recover*

the key assuming the flip has occurred - the authors report no first-party Rowhammer attack on physical DRAM and name no platform, and they note the same vulnerability "can also be triggered with other types of persistent fault attacks on memory like optical faults." The fault-delivery half of the chain is Section 7.2's Phoenix-class capability; the cryptanalysis half is this paper. Do not cite it as a demonstrated end-to-end hardware attack.

SLasH-DSA against SLH-DSA. [hw] Universal forgery against SLH-DSA by a **software-only** Rowhammer attack on commodity hardware with no physical access, demonstrated end-to-end against OpenSSL 3.5.1.

That last pair is the point of this section: the two hash- and lattice-signature schemes chosen partly for conservative security margins are both breakable through a memory-controller defect, without touching the cryptography.

7.3 Software-reachable power, frequency and voltage channels

Physical channels reached with no instrumentation. All CVE records below were verified against NVD.

Attack	Grade	CVE	Description (NVD, verbatim)	CVSS / vector
Hertzbleed (Intel)	[hw]	CVE-2022-24436	"Observable behavioral in power management throttling for some Intel(R) Processors may allow an authenticated user to potentially enable information disclosure via network access."	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Hertzbleed (AMD)	[hw]	CVE-2022-23823	"A potential vulnerability in some AMD processors using frequency scaling may allow an authenticated attacker to execute a timing attack to potentially enable information disclosure."	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Hertzbleed (Ampere)	[hw]	CVE-2022-35888	"Ampere Altra and Ampere Altra Max devices through 2022-07-15 allow attacks via Hertzbleed, which is a power side-channel attack that extracts secret information from the CPU by correlating the power consumption with data being processed on the system."	6.5 AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
PLATYPUS (driver)	[hw]	CVE-2020-8694	"Insufficient access control in the Linux kernel driver for some Intel(R) Processors may allow an authenticated user to potentially enable information disclosure via local access."	5.5 AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack	Grade	CVE	Description (NVD, verbatim)	CVSS / vector
PLATYPUS (RAPL)	[hw]	CVE-2020-8695	"Observable discrepancy in the RAPL interface for some Intel(R) Processors may allow a privileged user to potentially enable information disclosure via local access."	5.5 AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Plundervolt	[hw]	CVE-2019-11157	"Improper conditions check in voltage settings for some Intel(R) Processors may allow a privileged user to potentially enable escalation of privilege and/or information disclosure via local access."	6.7 AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Note the vectors, they carry the whole threat model. All three Hertzbleed CVEs are AV:N (network). Both PLATYPUS CVEs and Plundervolt are AV:L (local), and Plundervolt additionally requires PR:H - a privileged attacker, which matters because its target was SGX, where the threat model assumes exactly that.

No published work applies these specific software-reachable channels to ML-KEM or ML-DSA implementations as of this writing. That is stated as a gap, not extrapolated into a claim. The mechanism is scheme-agnostic and the schemes are new; treat absence of published work as absence of research attention, not as evidence of resistance.

7.4 Entropy-source manipulation

The entropy source is the floor under every key on the device, and it is physically manipulable. NIST SP 800-90B governs entropy-source design, health tests (startup, continuous, on-demand) and validation. FIPS 203 requires approved randomness; ML-DSA hedged signing and SLH-DSA randomized signing consume it continuously.

[hw] Ring-oscillator TRNGs are susceptible to frequency-injection locking, in which an injected supply frequency destroys jitter entropy (Markettos & Moore, CHES 2009). *The specific keyspace-reduction figures widely quoted from that paper are not reproduced here - the PDF could not be retrieved for verbatim verification during research, and per Section 3 an unverified number is omitted rather than repeated.* The mechanism is well established; the magnitudes require a first-party read before they appear in a GreyNOC artifact.

Control: require SP 800-90B validated entropy with continuous health tests, and treat power-rail filtering and on-chip regulation as *security* controls rather than EMC controls.

8. Tier B - bench and laboratory attacks

Requires unattended physical possession. **No runtime detection exists for anything in this section.** Its value is design-time and procurement requirements, and an honest actor-tier rating.

8.1 Why light gets into a chip at all

Silicon's room-temperature bandgap is about 1.12 eV, corresponding to roughly 1110 nm; above that wavelength single-photon absorption is forbidden, so silicon becomes transparent. Absorption falls steeply but does not switch off around 1100 nm - measured coefficients are 64 /cm at 1000 nm, 16.3 /cm at 1050 nm, 3.5 /cm at 1100 nm, 0.68

/cm at 1150 nm, 0.022 /cm at 1200 nm.

This single material property is why the backside of a die is an attack surface, why 1064 nm is the standard backside laser wavelength, and why **the probing band overlaps the fiber-optic bands of TX-02** - 1.3 μm optical probing sits in the same spectral neighborhood as O-band transport. The two playbooks describe the same photons doing different jobs.

A frequently-cited "700 μm penetration depth at 1.06 μm " figure appears in Skorobogatov & Anderson (CHES 2002) - but [re]layed, they cite it to a third party, and the sentence immediately following says focusing "is restricted by dispersion to several micrometers, and this is not precise enough." Quoting the depth without the focusing caveat inverts the paper's meaning.

8.2 Laser fault injection

[hw] Frontside attacks use 532 nm; backside attacks use 1064 nm, and the split is set by the absorption behavior above. Commercial tooling is openly sold - the Keysight DS1112A is a 1064 nm multimode fault-injection laser [vendor] rated 30 W pulse power, pulse width as small as 2 ns, up to 50 MHz (Keysight datasheet figures, unaudited).

Reported spot sizes cluster at 0.5-1 μm . **This is a tooling limit, not a diffraction limit** - NetSPI attributes its spot to "a low-cost, manually adjustable optical path," and Krachenfels et al. report $\sim 1 \mu\text{m}$ without a solid immersion lens. Describing it as diffraction-limited overstates the physics and understates how much better a funded adversary can do.

Two-photon-absorption LFI uses sub-bandgap wavelengths with femtosecond pulses, where the absorption coefficient is almost zero and penetration depth exceeds $10^5 \mu\text{m}$; the nonlinear response can be narrower than the Abbe limit. At equal power, 1064 nm single-photon absorption generates roughly $6\times$ higher electron-hole density, leading to latch-up and unwanted damage - which is why TPA is preferred for precision work.

Historical baseline worth keeping for perspective: [hw] a \$30 second-hand camera flashgun and an \$8 laser pointer could set or reset any individual SRAM bit in a Microchip PIC16F84 after standard depackaging (CHES 2002) - while the paper notes the best-designed secure microcontrollers of that era already resisted single laser flashes.

Against PQC specifically: [hw] laser fault injection against the random-seed pointer used in polynomial sampling yields full key and message recovery for ML-KEM and signature forgery for ML-DSA, with success rates up to 100%, on an STM32H7 - and the affected code pattern is reported present in pqm4, liboqs, PQCclean and wolfSSL (ePrint 2025/2009). That is a source-level finding a defender can act on today.

8.3 Photonic emission analysis

[hw] Switching CMOS transistors emit photons through hot-carrier luminescence at the drain edge, dominant in n-type devices, with generation rate proportional to supply voltage and switching frequency. Emission must be observed from the backside because frontside metal blocks the photons; InGaAs sensors work above $\sim 1 \mu\text{m}$ where silicon is transparent, so **substrate thinning becomes unnecessary**.

Demonstrated outcomes: a full AES-128 key recovered from an ATmega328P via SRAM row-decoder emissions with the backside polished to $\sim 25 \mu\text{m}$ remaining substrate and 120 s emission images (CHES 2012 - noting the target was a proof-of-concept AES implementation the authors wrote); and 100% of the secret key bits of 2048-bit RSA keys recovered with as few as 4,000 decryptions, with Montgomery's Ladder the most susceptible of the three implementations tested (ePrint 2017/108).

Two countermeasure facts that routinely surprise architects: memory encryption and scrambling have no effect on optical emission, and scrambling can make the attack *easier*. Shields and meshes generally protect only the frontside.

8.4 Optical probing - EOFM, LLSI, LVP/LVI

[hw] Electro-optical frequency mapping scans $>1\ \mu\text{m}$ light through the backside; transistor electric fields modulate the reflected light's amplitude and phase, and narrow-band filtering yields a 2-D map of nodes switching at a chosen frequency. Laser logic-state imaging extends this to recover *static* logic state with no switching activity, by modulating the core supply so only on-state transistors respond.

Demonstrated: laser voltage probing at $1.3\ \mu\text{m}$ on a 60 nm Altera Cyclone IV recovered the plaintext "red key" of a PUF-protected bitstream-encryption scheme (CHES 2016) - **a proof-of-concept the authors built themselves, not a shipped product**. And backside optical contactless probing broke commercial 28 nm FPGA bitstream encryption at $\sim 1\ \mu\text{m}$ resolution, without silicon polishing, in under 10 days of analysis (CCS 2017).

Silicon light sensors are structurally blind to this attack at practical probing intensities - silicon barely absorbs sub-bandgap light (Section 8.1 gives the measured coefficients: $0.68\ /\text{cm}$ at 1150 nm, $0.022\ /\text{cm}$ at 1200 nm), so no meaningful photocurrent trips the sensor. Stated as a bound rather than an absolute, per Section 3. This is the load-bearing defensive fact of the section: the standard on-die countermeasure does not apply.

Why advanced nodes do not save you, stated correctly. Detecting a bit is not the same as resolving a transistor: optical probing only requires the response image to differ between logic 0 and 1. Memory cells do not scale with the logic node - measured examples include $2.8 \times 3.1\ \mu\text{m}$ BBRAM on a 20 nm FPGA and $2.5 \times 1.9\ \mu\text{m}$ SRAM on a 180 nm MCU. Resolution is $\sim 1\ \mu\text{m}$ without a solid immersion lens and approximately 200 nm with one ([reLayed] - Krachenfels et al. cite this figure to others; their own measured value is the $1\ \mu\text{m}$ without-SIL number). Optical probing is reported as reaching obsolescence at "sub-7nm" nodes, motivating electron-beam probing at roughly 20× better spatial resolution (ISTFA 2023) - *"sub-7nm" there is the source's node-generation label, used as a technology boundary and not as a dimension, per Section 3.*

Bare-die flip-chip packages need no preparation at all for backside access, and flip-chip is increasingly prevalent at 20 nm and below.

8.5 Actor tiering - who can actually do this

Capability without cost is fearmongering. Published figures:

- A combined thermal-laser-stimulation + LLSI setup $\sim \$1\text{M}$; TLS-only $\sim \$100\text{k}$; **a laser scanning microscope can be rented for about \$300/hour including an operator**. Rented capability is a distinct actor tier and should be modeled as one.
- Integrated PICA systems started around $\text{€}1\text{M}$ in 2012; the CHES 2012 alternative cost approximately the price of a mid-range oscilloscope.
- JIL ("Application of Attack Potential to Smartcards and Similar Devices") classifies failure-analysis-grade equipment - FIB, SEM, abrasive laser - as *Bespoke*, the second-highest of four tiers (rating points: None 0/0, Standard 1/2, Specialized 3/4, Bespoke 5/6, Multiple Bespoke 7/8), notes only a small number of experts operate it, and allows renting to reduce the rating.
- **PSA Certified Attack Methods v1.3** rates laser fault injection only *specialized* equipment with an attack rating of 21 or more - "unlikely to be in scope for Level 3", and required consideration for Level 4.

The number to put in a risk register is not the per-tool rating but the **escalation rule**: where clearly different specialized benches are needed for distinct attack steps, the rating escalates. A real invasive chain escalates; do not let "low-end FIB is only Specialized" stand alone.

9. Tier C - fabrication and supply chain

9.1 Hardware trojans - what was actually demonstrated

Precision matters here more than anywhere else in the playbook, because this area is heavily mythologized.

Dopant-level trojans [sim] (Becker et al., CHES 2013) are built by flipping the dopant polarity of existing transistors, adding no gates, transistors or wires. Evaluated against a post-processing block derived from Intel's Ivy Bridge RNG and an iMDPL AES SBox. The RNG trojan sets all flip-flops storing the AES key to constants and (128-n) of the 128 flip-flops storing the input to constants, leaving n bits of real entropy while output still passes the NIST statistical test suite at $n = 32$; the design's own BIST was defeated at a cost of about 2^{31} offline tries against a 32-bit CRC.

This work was never fabricated in silicon. It was layout-level in the 45 nm Nangate Open Cell Library, verified with DRC, Calibre PEX and HSpice, with the side-channel attack conducted on *simulated* power traces. And the stealth claim was specific - against optical reverse engineering and golden-chip comparison - not against all physical inspection.

The stealth assumption was subsequently contradicted. Sugawara et al. (ePrint 2014/508) demonstrated detection using SEM and FIB imaging exploiting passive voltage contrast after delayering to the contact layer - though note they measured a dedicated chip built on the same principle, not a Becker-trojaned device.

A fabrication-time trojan has been demonstrated in real fabricated silicon. the A2 analog trojan [hw], built in 65 nm CMOS inside an OR1200 processor and weaponized as remotely triggerable privilege escalation, at a cost of as little as one gate (IEEE S&P 2016). When a threat model needs a demonstrated fabrication-time trojan, this is the citation - not the dopant work.

9.2 Malicious key generation - the PQC-native supply-chain attack

[analysis] A generic backdoor mechanism applies to LWE-like public-key cryptosystems including ML-KEM (Kyber), ML-DSA (Dilithium), FrodoKEM and HQC: key generation is manipulated so an adversary holding secret backdoor information can recover private keys from public keys, while the output is **indistinguishable from legitimate key generation** to the user (Hemmert, BSI, ePrint 2022/1381).

This is far cheaper and far more valuable than a dopant-level trojan, and it is the bridge between Section 9.1 and the algorithms. The proposed countermeasure is directly actionable: derive both public and private keys pseudorandomly from a single seed included in the private key, so a user can **regenerate the keypair with an independent implementation** and detect the subversion.

Procurement question this creates: for any device that generates its own long-lived PQC keys, can you regenerate and verify that keypair from a seed using independent software? If not, you are trusting the generator absolutely.

9.3 Counterfeits and provenance

Counterfeit types are classified into **seven** categories - recycled, remarked, overproduced, out-of-spec/defective, cloned, forged documentation, and **tampered** (die-level trojan, package level, or software/firmware). The seventh is what links counterfeiting to Section 9.1 and is the one most often dropped from summaries. Recycled and remarked jointly account for more than 80% of incidents ([relayed] - an industry estimate carried into a survey).

Detection splits into physical inspection (low-power visual, X-ray, SEM, SAM, decapsulation, XRF/FTIR/EDS) and electrical inspection (parametric, Iddq, path-delay fingerprinting via clock sweeping, one-class classifiers trained on new devices only). Avoidance is distinct from detection: CDIR aging odometers, PUFs, secure split test, hardware metering, package IDs.

9.4 What attestation does and does not cover

This is the most consequential misunderstanding in hardware supply-chain security.

- **RFC 9334 (RATS Architecture) is Informational**, not Standards Track, and deliberately does not standardize how an Attester's signatures are validated.
- **The hardware root of trust is not itself attested.** RATS defines roots of trust as the components for which no Evidence is generated, and which must be vouched for by manufacturer Endorsement.
- **Evidence covers operational status, health, configuration, construction claims and code/memory measurements - not silicon provenance, mask integrity, or absence of fabrication-time modification.**
- **Caliptra explicitly places out of its threat model:** manufacturing operational security, foundry IP integration, physical design countermeasures, OSAT test/initialization, and invasive depackaging/delaying attacks. (Caliptra does use dual ECC secp384r1 + ML-DSA-87 signatures in its certificates and supports LMS verification for firmware - good PQ hygiene, orthogonal to the physical threat.)

So: attestation tells you what software is running on the silicon you were given. It tells you nothing about whether that silicon is what you ordered. Any risk register that treats attestation as supply-chain assurance has a gap exactly the size of Section 9.1 and Section 9.2.

9.5 Concentration risk

EUV lithography exposes at 13.5 nm, roughly 15× shorter than the 193 nm ArF DUV it supplements. As of its FY2021 Form 20-F, ASML stated it is "the world's only manufacturer of EUV lithography systems", and its 2025 Annual Report identifies Carl Zeiss SMT as sole supplier of critical optical components. Date-stamp any statement of this kind rather than asserting it in the present tense.

A cautionary note for threat modeling: the most widely cited alleged real-world hardware implant in commercial servers was publicly contradicted by DHS and the UK NCSC. Hardware-implant claims require the same evidence bar as any other finding.

10. PQC exposure by scheme

Published, verified attacks against implementations of the standards. Platform is ARM Cortex-M4 unless stated. Every entry is graded per Section 3.

10.1 ML-KEM (FIPS 203)

Attack	Grade	Recovers	Notes
Compiler-emitted secret-dependent branch in <code>poly_frommsg</code> (Clangover / CVE-2024-37880)	[hw]	Long-term secret key	Network vector; minutes; reference code before 9b8d306
Secret-dependent division timing (KyberSlash1 / KyberSlash2)	[hw]	Long-term secret key	Source-level defect, distinct from CVE-2024-37880 and separately patched ; minutes (KS2) to hours (KS1)
Generic EM chosen-ciphertext on CCA decapsulation	[hw]	Long-term secret key	"In minutes", pqm4 implementations
CPA + lattice reduction, two-step	[hw]	Long-term secret key	<=15 traces, ~9-10 min, all three parameter sets
FO re-encryption leakage as plaintext-checking oracle	[hw]	Long-term secret key	Works against masked implementations

Attack	Grade	Recovers	Notes
Instruction-skip fault in message decoding	[hw]	Long-term secret key	~6,500 faulty decapsulations, clock glitch
Instruction-skip defeating the FO equality test	[hw]	Turns KEM into a decryption oracle	Also NTRU, Saber, BIKE, SIKE
Laser FI on random-seed pointer	[hw]	Key and message	Up to 100%; pattern present in pqm4, liboqs, PQClean, wolfSSL
Chosen-ciphertext <i>k</i> -trace on masked CCA2	[sim]	Long-term secret key	Leakage model only - no measured traces
Single-trace template on the NTT	[hw]	Session key only	213 templates; targets <i>encryption</i> , so the long-term key is not exposed
Single-trace power on message encoding	[hw]	Session key	100% for Kyber and Saber
DL power analysis vs 5th-order masked Kyber	[hw]	Session key (message) , not long-term key	Widely misreported as a full key break
Voltage FI + DL vs masked <i>and</i> shuffled	[hw]	Session key	Success 0.122 -> 0.887 with 32 key bits enumerated

Two rows are commonly overstated in secondary sources and are corrected here: the NTT single-trace attack targets encryption and therefore recovers only the transmitted symmetric key, and the fifth-order masked break is a *message-recovery* attack. Both are serious; neither is long-term key recovery.

10.2 ML-DSA (FIPS 204)

Attack	Grade	Outcome
Single-trace SCA on rejection sampling	[hw]	Private key, 100% success, seconds to minutes, all three levels
Non-profiling attack using public-data templates built on the target device	[hw]	Key recovery in ~300 traces (96 for challenge recovery); works in hedged mode
Profiled template on an intermediate signing vector	[hw]	Universal forgery; 700,000-message corpus
DFA on deterministic signing	[hw]	Secret key element from a single random fault; up to 65.2% of signing time vulnerable
Correction faults on randomized signing	[hw]	Key from 512-1024 faulty signatures
Single-fault attack on hedged signing	[hw]	Secret key vector, $p = 0.582$ in a single trace
EMFI on bit-sliced NTT	[hw]	~10% exploitable faults (667 MHz Cortex-A9)
Formal fault analysis of hedged ML-DSA	[analysis]	Resists faults at certain I/O points; key recovery at others

Signing-mode policy is auditable today, and the honest statement is two-sided. RFC 9882 states that ML-DSA signers SHOULD NOT use the deterministic variant on platforms where side-channel or fault attacks are a concern - and randomized ML-DSA is also *cheaper* to protect, so security and performance point the same way. But hedged mode is a **partial** countermeasure, not a fix: the single-fault break at $p = 0.582$ and the ~300-trace non-profiling recovery both operate against hedged signing. Recommend hedged; do not claim it closes the class.

10.3 FN-DSA / Falcon (FIPS 206, in development)

[hw] "Falcon Down" (Karabulut & Aysu, DAC 2021) is a known-plaintext differential electromagnetic attack targeting the floating-point multiplications inside Falcon's FFT via an extend-and-prune strategy, mapping recovered sign, mantissa and exponent values back to secret-key coefficients. Approximately **10,000 measurements** suffice to extract the entire key from the NIST reference software on a Cortex-M4, and the key permits forging signatures on arbitrary messages. Notably it requires no pre-characterization of the device.

Combined with Crowhammer (Section 7.2), FN-DSA/Falcon has both a demonstrated lab-grade EM attack [hw] and a cryptanalytic single-bit-flip key-recovery result [analysis] whose fault could be delivered by Rowhammer or by optical means. Per CONVENTIONS Section 1, FIPS 206 remains in development - do not claim FIPS 206 compliance, and weigh this implementation-security picture when considering Falcon for new designs.

10.4 SLH-DSA (FIPS 205)

- [hw] Software-only universal forgery via Rowhammer against OpenSSL 3.5.1 (Section 7.2).
- [analysis] A single random bit flip anywhere in SPHINCS+ signing substantially degrades security with high probability, and **the resulting faulty signature is not detected by the standard verification procedure**; the caching countermeasure can be circumvented with a tolerable number of queries.
- [hw] DPA recovered at least a 32-bit chunk of the SPHINCS-256 secret key from the hardware implementation evaluated in ePrint 2018/673. Name the specific device in any derived report - Section 3 requires a named platform for an [hw] grade, and "a hardware implementation" does not meet it.

The conservative, hash-based scheme is not physically conservative.

10.5 LMS / XMSS (SP 800-208)

For stateful hash-based signatures the dominant hazard is **state handling, not leakage** - DPA resistance of XMSS reduces to that of its underlying PRNG, and current versions are not threatened unless a customized PRNG is used.

- [norm] SP 800-208 Section 8.1 requires the module to update the private-key state in non-volatile storage **before** exporting a signature or accepting another signing request. It further binds key and signature generation to hardware modules at FIPS 140-2/140-3 Level 3+ physical security, non-modifiable or limited operational environment, no bypass mode, no export of private keying material, and the entropy source inside the module boundary. **This is the only place in the PQC standards corpus where physical security is normatively mandated** - use it.
- [norm] HSS/XMSS^{MT} implementations that re-sign a subtree root on every signature reuse a one-time key and are fault-injectable; sign each tree root exactly once.
- [hw] Faulting the WOTS+ checksum enables existential and, in advanced settings, universal forgery against LMS, XMSS and SPHINCS+, affecting both signing and verification. A laser fault injection attack on WOTS as used in XMSS has been practically evaluated on a standard microcontroller in a BSI-commissioned Fraunhofer AISEC study.
- Operational hazard that is pure cloud practice, not physics: process forking, VM cloning, snapshot restore, and backup restoration can silently reintroduce a used one-time key (`draft-ietf-pquip-hbs-state`, which replaced the expired `draft-wiggers-hbs-state`).

11. The assurance gap - the headline procurement finding

FIPS 140-3 was published 22 March 2019 and is not a standalone technical standard: it adopts ISO/IEC 19790:2012/Cor.1:2015 for requirements and ISO/IEC 24759:2017 for testing. **Its own text states that its major change relative to FIPS 140-2 was the introduction of non-invasive physical requirements** - and it treats "physical security" and "non-invasive security" as two separate requirement areas among eleven.

That requirement area was never populated:

- **SP 800-140F** - the CMVP document that replaces ISO/IEC 19790 Annex F - in its final published form (March 2020) approves **no test metrics at all**.
- A **draft Revision 1** (August 2021) would have adopted ISO/IEC 17825, ISO/IEC 20085-1 and ISO/IEC 20085-2 as approved metrics. **It has never been finalized**.
- The current FIPS 140-3 Implementation Guidance (last updated 16 April 2026) contains an **entirely empty Section 8 "Non-invasive security"** and an **entirely empty Annex F**. The strings "side-channel", "side channel" and "leakage" do not appear anywhere in the document.
- **CAVP algorithm validation tests only input/output behavior**, so an unhardened implementation and a heavily masked one are indistinguishable to it.
- CMVP is meanwhile actively validating PQC algorithms - the IG carries detailed self-test (CAST) requirements for ML-KEM, ML-DSA and SLH-DSA - while approving **no side-channel test metric** for them or for anything else. One indirect hook does exist and is worth knowing: IG 12.A "Mitigation of Other Attacks" provides that where a module has been *purposely designed, built and publicly documented* to mitigate a specific attack, that claim is documented and assessed. It is vendor-initiated and claim-scoped, not a level-driven mandate, and it approves no metric - so it does not convert a validation into side-channel assurance. Ask what was claimed, not whether the module is validated.

Therefore: a FIPS 140-3 validated ML-KEM module, and an ACVP/CAVP certificate for an ML-KEM implementation, convey no side-channel assurance whatsoever. That sentence belongs verbatim in procurement documents and vendor questionnaires.

What the PQC standards themselves say. FIPS 203 (ML-KEM) contains **no mention** of side-channel, timing, power or fault attacks anywhere in the document - a full-text search of the published PDF for "side-channel", "side channel", "timing attack", "power analysis" and "fault" returns nothing, and that search is recorded here so the negative is reproducible rather than asserted. FIPS 204 addresses them only as advisory prose - hedged signing helps, the deterministic variant "should not be used" where side-channel attacks are a concern. FIPS 205 has a run-in paragraph headed "Side-channel and fault attacks." inside Section 3.2 Implementation Considerations, using "care must be taken" rather than a normative "shall". SP 800-227 (final, September 2025) places side-channel protection in Section 3.3 under a heading reading "Additional Requirements" - but uses "should", and its own glossary reserves "shall" for requirements tested by a CMVP laboratory. [adv] throughout, [norm] nowhere.

The ISO track has moved ahead of the US track. ISO/IEC 19790:2025 (third edition, 2025-02) folds ISO/IEC 17825 into its Annex F, and ISO/IEC 24759:2025 normatively references ISO/IEC 20085-1 and -2. FIPS 140-3 still points at the 2012 and 2017 editions, so none of this reaches a CMVP validation. ISO/IEC 17825:2024 covers timing analysis, SPA/SEMA and DPA/DEMA for security levels 3 and 4 only, restricts itself to first-order attacks, and - creditably - **states in its own Introduction that the achievable confidence level is "low to medium"** and that more sophisticated attacks can still succeed against a module that passes. Peer-reviewed work has additionally found that its fixed-versus-random methodology does not transfer cleanly to lattice KEMs, because public and private key components are tightly linked.

The lever that does exist. Common Criteria AVA_VAN.5 is a white-box activity - it depends on ADV_IMP.1, so evaluators receive implementation representation in addition to conducting independent penetration testing - and smartcard/secure-element practice is governed by JIL v3.2.1 (February 2024), built around AVA_VAN.5 with a dedicated side-channel section. **But JIL v3.2.1 contains no post-quantum content at all:** a full-text search returns no occurrences of "quantum", "lattice", "ML-KEM", "ML-DSA" or "Kyber".

Procurement position, stated plainly:

1. Require **CC AVA_VAN.5 under JIL** for any device holding a long-lived PQC key.

2. Because JIL has no PQC content, **demand PQC-implementation evidence explicitly** - do not assume the scheme covers it. Ask which of the Section 10 attack classes were tested, against which parameter set, on which silicon.
3. For LMS/XMSS you already hold a mandate: **SP 800-208 Section 8.1**. Cite it.
4. Treat FIPS validation as evidence of algorithmic correctness only, and say so in the risk register.

The assurance you should demand is obtainable - this is not a hypothetical ask. On 24 January 2025 the German BSI certified Infineon's ML-KEM implementation on a TEGRION 28 nm security controller at **Common Criteria EAL6**, announced as the first CC certification of a post-quantum algorithm on a security controller, with BSI explicitly citing resistance to classical attacks including **fault attacks** alongside quantum-computer attacks. CC EAL6 mandatorily includes AVA_VAN.5.

That matters more than a negative would have. It means a procurement team asking for AVA_VAN.5 evidence on a PQC implementation is asking for something a vendor has already delivered and a national scheme has already certified - so "nobody does that yet" is not an acceptable answer. Verify the specific certificate covers the specific implementation, algorithm and parameter set you are buying, and check its date: certification is per-product, and one certificate does not generalize across a vendor's catalog.

12. Detection strategy - and what cannot be detected

Tier A is detectable and testable. Everything else is not, and the playbook says so.

A1 - Build-chain constant-time assurance. The most valuable control in this document, because CVE-2024-37880 was a compiler defect:

- Pin and record compiler, version and optimization flags in the SBOM for every PQC implementation.
- Run dynamic constant-time analysis **on the shipped binary**, not the source.
- Confirm libraries are past the Kyber 9b8d306 remediation (Clangover / CVE-2024-37880) **and** separately carry the KyberSlash patches - these are two defects with two fixes, and clearing one does not clear the other.
- Make "constant-time verified with what tool, at what optimization level, on what target" a mandatory vendor answer, and re-verify on every toolchain bump.

A2 - Rowhammer telemetry. Performance-counter-based hammer detection is deployable; treat known evasion and false-positive behavior as tuning work, not as a reason to skip it. Inventory DRAM by vendor and manufacture date against CVE-2025-6202's 2021-01 to 2024-12 range. **Never record on-die ECC as a mitigation.**

A3 - Software-reachable power and frequency interfaces. Restrict RAPL/energy telemetry to privileged users, apply the relevant microcode, and treat DVFS-derived timing as a reason to pin frequency or require frequency-independent implementations on key-handling hosts.

A4 - Signing-mode and state audit. Assert hedged ML-DSA in configuration; for LMS/XMSS, verify state-update atomicity and hunt for the cloning hazards - snapshot restores, VM clones, forked signer processes, restored backups - which are ordinary infrastructure telemetry.

A5 - Entropy health. *Sustained* health-test failures, and any persistent anomaly in noise-source output, are security events rather than hardware-maintenance events. Isolated failures are expected: SP 800-90B's continuous tests carry a deliberate non-zero false-positive rate, so alert on a threshold sustained across windows, never on a single failure (Section 14 rule 3).

A6 - Verifier-side fault resistance. Signature *verification* is an attack target, not just signing: faulting the WOTS+ checksum affects **both signing and verification** for LMS, XMSS and SPHINCS+ (Section 10.5), and a faulted SPHINCS+ signature is not caught by the standard verification procedure (Section 10.4). Every other control in this

playbook is signer-side, which leaves the more widely deployed half of the deployment unaddressed - there are far more verifiers than signers. For any PQ verifier on a physically reachable device (firmware bootloader, secure element, vehicle ECU, set-top box, smart meter), require the vendor to state what fault resistance the *verifier* carries, and treat "the signer is in an HSM" as a non-answer.

Undetectable at runtime, stated for the record: optical probing, photonic emission analysis, laser fault injection on a device out of your possession, FIB edit, dopant/analog trojans, and malicious key generation. For these, detection is replaced by (a) custody and tamper evidence, (b) inspection sampling, (c) provenance verification, and (d) blast-radius reduction. A device that left your control and came back is not "clean because nothing alerted."

13. Key Indicators

What an analyst actually looks for. Grouped by where the observable lives, and honest about the fact that the invasive tiers contribute *state* indicators rather than *event* indicators - there is nothing streaming to watch.

Build and dependency plane

- A PQC implementation in the SBOM at or below a known remediation floor - Kyber reference code predating commit `9b8d306`, or a library that has not taken the KyberSlash patches.
- No constant-time verification record for a shipped PQC binary, or a record that targeted the *source* rather than the binary.
- Compiler identity or optimization flags absent from the SBOM, or changed since the last verification run.
- A constant-time tool reporting a variable-time instruction or a secret-dependent branch on a secret operand - a BR hit in `poly_frommsg` being the CVE-2024-37880 signature specifically.
- Divergence between `-00` and `-02` verification results for the same source tree.

Platform and memory plane

- DRAM in the fleet matching a published Rowhammer-vulnerable vendor and manufacture window, with no refresh-interval override applied.
- On-die ECC recorded as the sole Rowhammer mitigation.
- Row-activation rates and clustered aggressor patterns above the site baseline, especially on a host that signs.
- A step change in corrected-error rate on a single DIMM.
- Unrestricted RAPL or energy-telemetry interfaces readable by unprivileged users.
- Software-writable voltage/frequency MSRs on a host holding keys, or missing microcode for the Plundervolt and PLATYPUS mitigations.

Cryptographic configuration and state plane

- ML-DSA configured for deterministic signing on a platform whose physical exposure is not controlled.
- An LMS/XMSS leaf-index observation at or below the last recorded value - one-time key reuse, and a cryptographic break rather than a hygiene issue.
- A signature emitted after a state-store write failure, or state persisted *after* rather than before export.
- Any HSS/XMSS^MT signer re-signing a subtree root more than once.
- VM clone, snapshot restore, backup restore, or process fork touching a stateful-HBS signer.
- A long-lived PQC keypair generated on-device that cannot be regenerated from a seed with independent software.
- SP 800-90B continuous health-test failures, or a step change in noise-source bias, on a key-generating device.

Physical and supply-chain plane - *state, not events; none of these stream*

- Broken or missing tamper evidence on a module holding a code-signing, device-identity or root key.
- A device holding long-lived keys returning from any period outside verified custody.
- Module vendor, part number, serial or firmware failing reconciliation against the procurement record - reconciled against procurement, never against what the part reports about itself.
- An unexplained in-service transceiver or secure-element firmware change.
- Bare-die flip-chip packaging on a device whose threat model assumed physical inaccessibility (no preparation is needed for backside access).
- A vendor threat model that excludes depackaging, delayering, foundry IP integration or manufacturing operational security - which is the documented default, not an exception.

Assurance plane

- FIPS 140-3 validation cited as evidence of side-channel resistance (Section 11) - an indicator of a documentation defect, and the most common one in this domain.
- No CC AVA_VAN.5 evidence for a device holding a long-lived PQC key, or AVA_VAN.5 evidence that predates and therefore does not cover the PQC implementation.
- Any claim of a "Planck-scale", "sub-Planck" or comparable attack surface - a provenance defect in the source document (Section 3), never a technical finding.

14. Sample Detection Logic (JSON-style)

```
{
  "rule_name": "PQC - Non-Constant-Time Binary or Unremediated Implementation",
  "description": "Flags deployed PQC implementations whose binary has not been verified constant-time, or which predate known remediations. Targets the CVE-2024-37880 defect class where constant-time source compiles to variable-time code.",
  "data_source": ["SBOM.Component", "BuildPipeline.Metadata", "CTVerify.Report", "Asset.Inventory"],
  "pqc_library_set": [
    "pq-crystals/kyber", "pq-crystals/dilithium", "liboqs", "PQClean",
    "pqm4", "wolfSSL", "BoringSSL", "OpenSSL", "mlkem-native"
  ],
  "remediation_floor": {
    "_comment": "MAINTAIN THIS TABLE LOCALLY. Populate from each project's own security advisories and record the date you last refreshed it - a stale floor silently disables this rule.",
    "pq-crystals/kyber": "commit >= 9b8d306 (CVE-2024-37880 / Clangover) AND KyberSlash1+2 patches applied - two separate remediations",
    "_others": "record per-component remediated version, date, and source advisory URL"
  },
  "ctverify_tooling": {
    "options": [
      "patched Valgrind for variable-time-instruction detection on secret data (the KyberSlash authors' method, applied across 1000+ SUPERCOP primitives)",
      "dudect / ctgrind / TIMECOP-style dynamic checks"
    ],
    "requirement": "the analysed artifact MUST be the shipped binary at the shipped optimization level"
  },
  "logic": {
    "for_each": "pqc_implementation",
    "trigger_any": [
      "component.name in pqc_library_set and component.version < remediation_floor[component.name]",
      "ctverify.report absent or ctverify.report.target_artifact != 'binary'",
      "build.compiler_id + build.optimization_flags not recorded in SBOM",
      "build.compiler_id + build.optimization_flags changed since last ctverify.report",
      "ctverify.findings.variable_time_on_secret > 0",
      "ctverify.findings.secret_dependent_branch > 0"
    ],
    "escalate_if_any": [
      "asset.exposure == 'network_reachable'",
      "asset.holds_key_class in ['long_term_decapsulation', 'code_signing', 'device_identity']",
      "component.name == 'pq-crystals/kyber' and component.commit predates '9b8d306'"
    ]
  },
  "notes": "Source-level review does NOT satisfy this rule. The defect class is created by the compiler, so the verified artifact must be the shipped binary at the shipped optimization level. Track BRANCH findings and DIVISION findings separately - they map to two different defects with two different patches."
}
```

```

"severity": "critical_when_escalated_else_high",
"tags": ["CVE-2024-37880", "TX-03-7.1-compiler-induced-timing-leak", "pqc_implementation_defect"]
}

```

```

{
  "rule_name": "PQC - Rowhammer Exposure and Hammering Activity",
  "description": "Correlates DRAM fleet exposure with live hammer-pattern telemetry; Rowhammer is the delivery vehicle for software-only breaks of FN-DSA/Falcon and SLH-DSA.",
  "data_source": ["Hardware.Inventory.DIMM", "PerfCounter.MemoryActivation", "EDAC.CorrectedErrors", "Platform.Config"],
  "logic": {
    "window": "1h",
    "exposure_assessment": {
      "_comment": "AND, not OR. DDR5 default tREFI is ~3.9 us and almost no fielded host overrides it, so an OR here would flag the entire DDR5 estate and make the inventory work meaningless.",
      "trigger_all": [
        "dimm.dram_manufacturer_id == 'SK Hynix'",
        "dimm.module_mfg_date within 2021-01..2024-12",
        "platform.trefi_override == false"
      ],
      "_field_note": "Key on the DRAM DIE manufacturer (DDR5 SPD bytes 552-553), NOT the module vendor (SPD 512-513 / SMBIOS Type 17). CVE-2025-6202 scopes to SK Hynix DDR5 dies, which ship under many module brands - dmidecode alone will misclassify.",
      "posture_flag_separately": "platform.mitigation_claimed == 'on_die_ecc_only' // a documentation defect, not evidence of hammering"
    },
    "activity_detection": {
      "_deployability": "NOT AVAILABLE AS FLEET TELEMETRY on commodity x86. Per-DRAM-row activation counts are not exposed; uncore IMC counters give aggregate ACT/CAS per channel with no row address. The only published mechanism (ANVIL, ASPLOS 2016) is an out-of-tree kernel module inferring row locality from PEBS-sampled LLC misses. Treat this block as a design target for platforms that DO expose the counters, and do not represent its absence as 'no hammering detected'.",
      "where_available": {
        "compute": {
          "row_activation_rate": "activations_per_row_per_refresh_window",
          "aggressor_pattern_score": "clustered_activation_entropy(row_addresses)"
        },
        "having": {
          "row_activation_rate_gte": "site_hammer_threshold",
          "aggressor_pattern_score_gte": "site_pattern_threshold"
        }
      },
      "practical_proxy": "EDAC corrected-error rate step-change on a single DIMM - weak, lagging, and not specific, but it is what most estates actually have"
    },
    "escalate_if_any": [
      "host runs a signing service using SLH-DSA or FN-DSA/Falcon",
      "host holds a code-signing or device-identity private key",
      "concurrent unexplained privilege escalation on the same host",
      "EDAC corrected-error rate step-change on the same DIMM"
    ],
    "notes": "On-die ECC is NOT a mitigation - published work shows flips accumulate because ODECC corrects only on write or on a long periodic cycle (e.g. every 24 h). A platform whose sole claimed mitigation is ODECC is exposed, not protected. Exposure assessment here is INVENTORY work and is fully deployable; activity detection largely is not - report the two separately so an empty activity queue is never read as assurance.",
    "severity": "critical_when_escalated_else_medium",
    "tags": ["CVE-2025-6202", "TX-03-7.2-rowhammer-fault-delivery", "fault_injection_via_software"]
  }
}

```

```

{
  "rule_name": "PQC - Signing-Mode, HBS State and Entropy Integrity",
  "description": "Audits the configuration and runtime invariants that published fault and side-channel attacks depend on.",
  "data_source": ["CryptoConfig", "HSM.Audit", "Signer.StateStore", "Entropy.HealthTest", "Virt.Events"],
  "logic": {
    "halt_signing_immediately": {
      "_comment": "Cryptographic-break conditions only. These are unambiguous and justify stopping production signing.",
      "trigger_any": [
        "hbs.signer_observed_leaf_index <= last_recorded_leaf_index",
        "hbs.tree_root signed more_than_once",
        "signature emitted after a state-store write failure",
        "hbs.state_update_ordering != 'persist_before_export'",
        "entropy.health_test_permanent_failure == true"
      ],
      "action": "halt_signing + preserve_state_store + alert",
      "severity": "critical"
    }
  }
}

```

```

    },
    "alert_only": {
      "_comment": "Real signals that must NOT auto-halt production. SP 800-90B continuous health tests (Repetition Count, Adaptive Proportion) are specified with a deliberate non-zero type-I error rate, so isolated failures are expected behaviour, not evidence of attack.",
      "trigger_any": [
        "entropy.health_test_failures >= site_threshold sustained across >= 2 consecutive windows (site_threshold derived from the module's documented type-I error rate and sample rate)",
        "entropy.noise_source_output_anomaly == true",
        "mldsa.signing_mode == 'deterministic' and asset.physical_exposure != 'controlled'"
      ],
      "action": "alert",
      "severity": "high"
    },
    "escalate_if_any": [
      "virt.event in ['vm_clone', 'snapshot_restore', 'backup_restore', 'process_fork'] affecting hbs.signer",
      "key_class == 'firmware_signing'"
    ]
  },
  "posture_assertions": {
    "_comment": "NOT detections. These are Tier C design properties with no runtime telemetry - asserted in the CBOM and reviewed at onboarding and change, per S12 and S17. Expressing them as runtime alerts would fire permanently across any HSM estate and create false assurance.",
    "seed_regenerable_keypair": "pqc_keypair.generated_on_device implies pqc_keypair.seed_regeneration_supported == true (S9.2 malicious key generation)",
    "review_points": ["device onboarding", "key ceremony", "vendor change", "annual attestation review"]
  },
  "notes": "The leaf-index regression and the clone events are the practical LMS/XMSS failure mode - far more likely than a laser. Separating halt-worthy breaks from alert-worthy anomalies matters operationally: a rule that halts a production signing service on a single expected health-test blip will be disabled within a week, taking the leaf-index check with it.",
  "tags": ["SP-800-208", "TX-03-10.5-hbs-state-integrity", "TX-03-9.2-malicious-keygen", "hbs_state_integrity"]
}

```

15. Example Evidence

```

SBOM / build metadata - constant-time verification gap
component: kyber-reference    version/commit: 3c8b5b1 (predates 9b8d306)
compiler:  clang 17.0.6      flags: -O2
ctverify:  ABSENT
asset:     tls-terminator-07  exposure: network_reachable
key_class: long_term_decapsulation
-> CVE-2024-37880 defect class. AV:N. Source review would not have caught this.

Constant-time analysis on the shipped binary (illustrative tool output shape)
fn: poly_frommsg    compiler-emitted secret-dependent branch  BR  HIT
fn: poly_tomsg      variable-time instruction on secret operand  DIV  HIT
fn: poly_compress   variable-time instruction on secret operand  DIV  HIT
-> 3 findings at -O2 (clang 17.0.6). Same source at -O0: 0 findings. <-- the whole point
BR hit in poly_frommsg = CVE-2024-37880 (Clangover), fixed by commit 9b8d306
DIV hits                = KyberSlash defect class, fixed by separate library patches
Two defects, two patches. Passing one check does not clear the other.

DRAM fleet exposure
host: sign-svc-03  DIMM vendor: <V>  mfg: 2023-07  trefi_override: false
claimed_mitigation: on_die_ecc
role: SLH-DSA firmware signing service
-> In CVE-2025-6202 exposure window; ODECC is not a mitigation; host performs
    exactly the operation SLASH-DSA forges. Escalate.

LMS/XMSS state-store anomaly
signer: fw-sign-01  leaf_index_recorded: 40961  leaf_index_observed: 40960
preceding event: snapshot_restore  2026-08-09T03:12Z
-> One-time key reuse. Signing halted. This is the realistic HBS failure mode.

ML-DSA signing configuration audit
service: token-issuer  mode: deterministic  platform: shared_cloud_host
-> RFC 9882 SHOULD NOT. Also the cheaper-to-protect option is the safer one.

Entropy health
device: hsm-04  sp800-90b continuous health test failures: 3 in 1h

```

```
noise_source_output: bias step-change at 02:41Z
-> Security event, not a maintenance ticket.
```

16. Investigation Steps

1. **Classify the tier before anything else (Section 6).** Tier A is a patch-and-verify workflow; Tier B/C is a custody-and-blast-radius workflow. Misclassifying wastes the first hour of an incident.
2. **For a suspected Tier A defect, reproduce on the shipped artifact.** Verify the binary at the shipped optimization level; a clean source review or a clean `-00` build proves nothing.
3. **Establish key scope immediately.** Which keys does this silicon hold, what do they sign or decapsulate, how long are they valid, how many relying parties trust them, and can they be revoked? Blast radius, not attack elegance, sets severity.
4. **For a device suspected of physical compromise: do not re-power it.** Preserve chain of custody, photograph in place, and treat the device key as disclosed until proven otherwise.
5. **Preserve before thermal handling.** Some radiation-induced fault effects are semi-permanent and anneal out - routine thermal handling can destroy the evidence of a physical attack.
6. **Reconcile the physical inventory.** Module vendor, part number, serial and firmware against the procurement record - reconcile against procurement, never against what the part reports about itself (Section 9.3).
7. **Determine whether the key could have been generated maliciously (Section 9.2).** If the device generated its own long-lived keypair and cannot regenerate it from a seed with independent software, that is an unfalsifiable trust dependency - record it as a finding regardless of the current incident's outcome.
8. **For HBS signers, reconstruct the state history.** Leaf-index sequence, every snapshot/clone/ restore event, and whether any signature was emitted after a state-store write failure. One-time key reuse is a cryptographic break, not a hygiene issue.
9. **Pull the assurance evidence and read it against Section 11.** If the vendor's answer is "it is FIPS 140-3 validated", that answer contains no side-channel information. Ask for the AVA_VAN.5 report and which Section 10 attack classes were in scope.
10. **Decide the rotation scope before remediation.** Per PB-25, treat every key reachable from the compromised boundary as exposed from the last verified-clean point, not from detection.

17. False Positive Considerations

- **Corrected-error counters rise for ordinary reasons** - aging, thermal stress, marginal DIMMs. Rowhammer detection requires the *activation pattern*, not the error count alone.
- **Legitimate memory-intensive workloads** (in-memory databases, HPC, compilers under load) produce high row-activation rates. Baseline per workload class.
- **Entropy health-test failures during boot or thermal transients** can be benign; sustained or repeated failure is not.
- **Constant-time tool findings on non-secret data** are noise; the finding must be on a secret-dependent operand, which is precisely what the patched-Valgrind approach establishes.
- **Deterministic signing is a legitimate choice** in some constrained or test contexts. Alert on it where physical exposure is uncontrolled, not universally.
- **Leaf-index gaps** can result from authorized key-rollover procedures; a *regression* cannot.
- **Vendor part-number changes** from second-sourcing and revisions are routine - reconcile against the procurement record before treating as counterfeit.
- **Physical tamper-evidence damage** occurs in shipping and handling. Investigate; do not assume.

18. Tuning Guidance

- **Prioritize by key scope and key lifetime, not by attack sophistication.** A device holding a ten-year firmware-signing key justifies Tier B/C controls; a TLS terminator with 90-day certificates does not.
- **Gate on the toolchain, not the source tree.** Re-run binary constant-time verification on every compiler, flag, or target change - that is the trigger condition for the entire Section 7.1 defect class.
- **Feed the PB-14 Mosca margin into physical controls too.** Long-shelf-life keys on physically exposed devices are the intersection that deserves budget.
- **Baseline DRAM activation per workload class** before enabling hammer detection, or the queue fills with databases.
- **Keep the evidence grades (Section 3) in the tuning record.** A control justified by a [sim] result should be labeled as such, so a future reviewer can re-weigh it when hardware results land.
- **Re-check the Section 11 certification position periodically.** It is a snapshot: if CMVP populates Section 8 or Annex F, or the set of PQC AVA_VAN.5 certificates grows, the procurement ask changes and the playbook must change with it.
- **Provenance gate for outbound artifacts (document review, not incident response).** Block any artifact heading to a customer, a risk register or a public report if it contains: a "Planck-scale", "sub-Planck" or comparable claim; a process-node name used as a physical dimension; a [sim] result presented as demonstrated; a CVSS vector restated as an achieved experimental outcome; or a relayed figure presented as a first-party measurement. This is a checklist run at review time, not a detection - it has no runtime trigger and belongs to no queue.
- **Do not tune Tier B/C into the alert pipeline.** They generate no runtime telemetry; expressing them as detections creates false assurance.

19. Response Actions

Immediate

- For Tier A: identify every asset running the affected implementation, prioritize by exposure and key class, and treat network-reachable long-term-key holders as urgent.
- For a device suspected of physical compromise: do not re-power, preserve custody, and assume key disclosure.
- Halt signing on any HBS signer showing a leaf-index regression, and preserve the state store before remediation.
- Where entropy health tests are failing, stop generating keys on that device.

Short-term

- **Rotate on the assumption the attack succeeded.** Scope from the **last verified-clean point**, defined operationally as the most recent moment satisfying *all* of: (a) documented unbroken physical custody, or intact tamper evidence, from that moment forward; (b) module serial and firmware reconciled against the procurement record; and (c) no unexplained gap in the device's own audit or attestation record. Where none of those can be established - which is the normal case for a device returned from an unmonitored period - the verified-clean point is **the date of the last key ceremony or provisioning event**, and the exposure window is everything since. Say which definition you used; the window is the finding. PB-25 governs the rewrap and rotation workflow.
- Patch and rebuild PQC implementations past the remediation floor, then **re-verify the binary** - a patched source built with the same toolchain is not evidence.

- Apply platform mitigations: refresh-interval override where exposed and supported (with the measured ~8.4% SPEC CPU2017 cost budgeted), RAPL restriction, microcode.
- Switch ML-DSA signers to hedged mode where deterministic mode is in use on exposed platforms, recording that this is partial mitigation.
- Revoke and reissue any certificate or firmware-signing key whose device cannot be shown to have remained in custody.

Long-term

- **Extend the CBOM (PB-01) to the silicon plane** - which module, which firmware, which entropy source, which physical security level, which keys are non-exportable, and whether keypairs are seed-regenerable.
- **Rewrite procurement language against Section 11.** FIPS validation for algorithmic correctness; AVA_VAN.5 under JIL plus explicit PQC-implementation evidence for physical resistance; SP 800-208 Section 8.1 cited directly for LMS/XMSS.
- **Design for blast-radius reduction, because it is the only control that covers Tier B and C:** per-device keys, short validity, no global signing key resident on a fielded device, functioning revocation, attestation that fails closed.
- Require seed-based regeneration for any long-lived PQC keypair generated on a device (Section 9.2).
- Add optical modules, secure elements and HSMs to supply-chain assurance (PB-27) with serial and firmware reconciliation at install.
- **Specify verifier-side fault resistance in procurement (Section 12 A6),** not just signer-side. The fleet contains orders of magnitude more verifiers than signers, and the WOTS+ checksum fault affects verification too.
- Where FN-DSA/Falcon is under consideration, weigh Section 10.3 - and note FIPS 206 is still in development, so a compliance claim is not available either way.

20. Escalation Criteria

Escalate to incident when **any** of the following are true:

- A PQC implementation with a known long-term-key-recovery defect is found on a network-reachable asset (the CVE-2024-37880 class).
- Binary constant-time verification finds a variable-time instruction on a secret operand in a shipped artifact.
- Hammer-pattern telemetry fires on a host performing PQC signing or holding a code-signing key.
- Any LMS/XMSS leaf-index regression, or any evidence of one-time key reuse.
- A signature was emitted after a state-store write failure.
- A device holding a long-lived private key returns from a period outside verified custody.
- Tamper evidence is broken on a module holding a code-signing, device-identity or root key.
- Entropy health tests fail persistently on a key-generating device.
- A module fails procurement reconciliation on **serial number**; or its firmware version was never released by the vendor for that part; or its firmware changed outside an authorized change record. (Routine vendor-released updates recorded in change management are not escalations - otherwise this criterion fires on every patch cycle and gets ignored.)
- A long-lived PQC keypair is found to be non-regenerable from a seed **and** the generating device or its supply chain is in question (Section 9.2). *(The provenance gate for "Planck-scale" and comparable claims is deliberately **not** an escalation criterion - by Appendix A.5's own measured base rate it would never fire, and a never-firing entry trains on-call staff to skim the list. It belongs in Section 17 as a document-review gate.)*

21. Analyst Notes Template

```

Incident ID:
Detection Rule / Tier (A | B | C):
Detected At / Detected By:
--- Asset ---
Device / Module / Serial:
Silicon (package type, bare-die flip-chip? Y/N):
Firmware version / matches procurement record? Y/N
Physical custody unbroken since: ____ Evidence: ____
--- Cryptography ---
Scheme(s):          ML-KEM | ML-DSA | SLH-DSA | FN-DSA | LMS/XMSS | ____
Parameter set:
Implementation / version / commit:
Compiler + version + optimization flags:
Binary constant-time verified? Y/N tool: ____ at flags: ____ findings: ____
Signing mode (ML-DSA):      deterministic | hedged
HBS state ordering verified: Y/N leaf index recorded/observed: ____ / ____
Keypair seed-regenerable:   Y/N independently verified: Y/N
Entropy source / SP 800-90B validated / health failures: ____ / Y/N / ____
--- Exposure ---
Key class:                session | long-term decapsulation | code signing | device identity | root
Key lifetime / relying parties / revocable? ____ / ____ / Y/N
Network exposure:
Last verified-clean point:      Exposure window: ____
Blast radius (keys reachable):
--- Assurance ---
FIPS 140-3 validated? Y/N <-- conveys NO side-channel assurance (§11)
IG 12.A vendor-claimed mitigation on file? Y/N what was claimed: ____
CC AVA_VAN.5 / EAL6+? Y/N certificate covers THIS algorithm+parameter set+product? Y/N
Verifier-side fault resistance stated by vendor (§12 A6)? Y/N
SP 800-208 §8.1 applicable / met (LMS/XMSS only): Y/N / Y/N
--- Evidence discipline ---
Every quoted figure graded [hw]/[sim]/[analysis]/[norm]/[adv]/[relayed]/[vendor]? Y/N
Any node-name used as a dimension? (must be N)
Any unverifiable-physics claim present? (must be N)
--- Handling ---
Device re-powered? (should be N) Thermal handling avoided? Y/N
Evidence preserved before remediation: Y/N (list)
Keys rotated / scope (PB-25):
Containment actions:
Coverage gap identified:
Outstanding Risks:
Recommendations:
Analyst:

```

22. Summary

Post-quantum cryptography does not execute in the abstract. It executes in silicon, where a key is a voltage, and where every published attack in this playbook breaks a *correct* implementation of a *standardized* algorithm without touching the underlying mathematics.

The actionable center of gravity is not where intuition puts it. The exotic tiers yield **no runtime detection whatsoever**; their output is procurement language and blast-radius design. Grade them precisely even in summary: optical probing, photonic emission and focused ion beam are demonstrated on real hardware [hw], as is the A2 analog fabrication-time trojan; **dopant-level trojans remain [sim]** - layout-verified and simulated, never fabricated (Section 9.1). Collapsing that distinction in a summary is how the overclaim Section 9.1 exists to prevent gets shipped. The deployable controls live almost entirely in the software-reachable tier: a compiler that silently destroys constant-time guarantees, a DRAM defect that forges hash-based signatures with no physical access, power and frequency interfaces that leak over a network, an entropy source that can be locked, and a signing mode set by one line of configuration.

Three positions to carry into any engagement built on this playbook. **Verify the binary, not the source** - CVE-2024-37880 is rated AV:N and recovers an ML-KEM-512 secret key in minutes because constant-time source compiled to variable-time code. (State the rating as a rating: AV:N is the CVSS vector NVD assigned, not a description of a demonstrated remote exploit.) **FIPS validation is not side-channel assurance** - FIPS 140-3 created a non-invasive requirement area, CMVP never populated it, and the Implementation Guidance's Section 8 and Annex F remain empty; require AVA_VAN.5 under JIL with explicit PQC evidence, because JIL itself has no PQC content. **And for anything an adversary can physically possess, assume the key is readable** - silicon light sensors cannot see the sub-bandgap light used to probe them, memory encryption does not conceal optical emission, and the only surviving control is that the key was small in scope, short in life, and revocable.

The physics floor is settled and closed (Appendix A): there is no Planck-scale attack surface, the finest limit that actually binds an adversary - optical diffraction - is some twenty-eight orders of magnitude coarser than the Planck length and entirely classical, and a claim to the contrary is a provenance defect in the document making it.

Appendix A - The Planck-scale investigation, and the physical floor

This appendix exists so the question is settled once, with numbers, and never re-argued. It was produced as a genuine investigation into whether a "Planck-length intrusion" could constitute an attack surface. It cannot. Here is why, and here is what actually bounds an adversary instead.

A.1 The verdict

No Planck-scale attack surface has been demonstrated, and no coherent construction of one has been found across the searches recorded in A.5. The Planck length, $1.616255(18) \times 10^{-35}$ m (CODATA 2022), is not a feature of any device; it is the scale at which the semiclassical description of spacetime is expected to fail. The strongest available device-independent argument - resting on causality, the uncertainty principle, and the hoop conjecture, the last of which is well supported by analytical and numerical work but remains **unproven** - indicates that no probe or target can be smaller than the Planck length, implying a Planck-size irreducible "minimum ball" of uncertainty in any position measurement, interferometers included. **That is a bound on measurement, not an accessible layer.** Probing it directly would require $\sim 1.220890(14) \times 10^{19}$ GeV, about 9×10^{14} times the LHC's 13.6 TeV proton-proton centre-of-mass energy, or $\sim 1.8 \times 10^{15}$ times its 6.8 TeV per-beam per-quantum energy - the highest energy achieved in a collider, though cosmic rays reach far higher single-particle energies without being steerable probes - and, on naive LHC-class bending-technology scaling, a ring of order 5×10^{19} m, roughly five thousand light-years. Every experimental program that reaches toward the scale does so indirectly, over cosmological baselines, and reports nulls with exclusion bounds. Information-theoretic bounds point the same way: holography limits the information content of adjacent spacetime regions to roughly 10^{69} bits per square metre of bounding **area**, not to any addressable volumetric Planck substructure. Accordingly this playbook records "Planck-length intrusion" as a term with no referent in information security, and treats its appearance in any artifact as a provenance defect to be reviewed, not a threat to be modeled.

A.2 The numbers

Quantity	CODATA 2022 value	Relative uncertainty
Planck length	$1.616255(18) \times 10^{-35}$ m	1.1×10^{-5}
Planck time	$5.391247(60) \times 10^{-44}$ s	1.1×10^{-5}
Planck mass	$2.176434(24) \times 10^{-8}$ kg	1.1×10^{-5}

Quantity	CODATA 2022 value	Relative uncertainty
Planck energy	$1.220890(14) \times 10^{19} \text{ GeV}$	1.1×10^{-5}
Planck temperature	$1.416784(16) \times 10^{32} \text{ K}$	1.1×10^{-5}

Planck energy expressed in SI is $\sim 1.956 \times 10^9 \text{ J}$ *per single quantum* - about 543 kWh, or roughly 0.47 tonnes of TNT equivalent. That is a unit conversion, not an independent measurement.

The gap. The LHC reached 13.6 TeV in Run 3 (6.8 TeV per beam, first delivered 5 July 2022). The ratio to Planck energy is 8.977×10^{14} - and because resolvable length scales as $L \sim \hbar c/E$, the gap is identical in energy and in resolvable distance. Scaling the LHC's 26,659 m circumference linearly at fixed dipole field to Planck energy per beam gives $\sim 4.79 \times 10^{19} \text{ m}$, about 5,060 light-years. That is a scaling estimate to convey magnitude, not an engineering study.

A.3 What the experiments actually found

Reported as nulls with exclusion bounds, per Section 3:

- Fermi-LAT / GRB 090510** set 95% CL limits of $E_{\text{QG},1} > 7.6 E_{\text{Planck}}$ (linear) and $E_{\text{QG},2} > 1.3 \times 10^{11} \text{ GeV}$ (quadratic) - the most constraining limits in that paper's own 2013 four-GRB sample, for the **subluminal** case, **without** correction for intrinsic source-frame dispersion. Both qualifiers must travel with the number, and the linear limit has since been superseded by LHAASO below.
- LHAASO / GRB 221009A** (2024) gives $E_{\text{QG},1} > 10 E_{\text{Planck}}$ and $E_{\text{QG},2} > 6 \times 10^{-8} E_{\text{Planck}}$, both 95% CL. The correct statement is: *no linear energy-dependence of the vacuum speed of light has been observed; linear LIV is excluded up to $10\times$ the Planck energy at 95% CL.* Not "no such effect exists."
- The Fermilab Holometer** reached $2.1 \times 10^{-20} \text{ m}/\sqrt{\text{Hz}}$ and, for signal *bandwidths* greater than 11 kHz - an integration bandwidth, not a Fourier-frequency threshold - its strain/shear power spectral density passed below the Planck time. It found no correlated holographic noise, and Fermilab's own summary is that it ruled out the specific "pixelated universe" model it was built to test to high statistical significance.

The one proposal that sounds like a channel - a "Planck broadcast" at $\sim 2 \times 10^{43} \text{ bits/s}$, the inverse Planck time - is a speculative theoretical hypothesis whose single concrete observable prediction is exactly the transverse position noise the Holometer searched for and did not find. It is not an engineerable channel, and reading it as a covert channel is the "speculative-channel laundering" failure mode named in Section 3.

A 2026 preprint proposes that a sufficiently large quantum computer could exceed the classical limit of one operation per Planck volume-time, with 500 logical qubits sufficient to reject lab-confined theories. It is **unrefered**, its 2^{491} figure matches the inverse Planck volume-time only to within a factor of ~ 1.5 , and - stated explicitly as this playbook's reading rather than the authors' - it concerns Hilbert-space scaling, not Planck-regime access. It is included because omitting a real preprint would be as dishonest as overstating it.

A.4 The floors that actually bind an adversary

These are the limits an engineer meets. The finest length among them - the Abbe limit - is about **28 orders of magnitude** coarser than the Planck length, and even the most extreme probe in A.2-A.3, the LHC's resolvable scale of $\sim 1.45 \times 10^{-20} \text{ m}$, is still ~ 15 orders of magnitude coarser. Their job in this playbook is to let a reviewer say "that is physically impossible" and be right.

Limit	Value	Why it matters here
Landauer	$kT \ln 2 = 2.87 \times 10^{-21}$ J per bit erased at 300 K	Experimentally confirmed with a single-particle one-bit memory. Real CMOS sits far above it - a first-principles analysis of CMOS switching, interconnect and leakage energy puts maximum CMOS efficiency at $\sim 4.7 \times 10^{15}$ FP4/J, roughly 200× above current microprocessors (Ho, Erdil & Besiroglu, arXiv:2312.08595 - unrefereed preprint, a geometric-mean estimate, and the unit is four-bit floating point, not generic FLOP), so Landauer is not the binding constraint on real hardware
Margolus-Levitin	"Adding one Joule of energy to a given computer can never increase its processing rate by more than about 3×10^{33} operations per second" - the authors' own stated figure , quoted verbatim	Bounds brute-force claims. Note for reviewers: recomputing the orthogonal-state rate as $4E/h$ gives $\sim 6 \times 10^{33} \text{ s}^{-1} \text{ J}^{-1}$, a factor of two above the authors' quoted number, because that expression counts orthogonal transitions rather than the authors' "operations". Cite the paper's figure with its wording, not a re-derivation
Bekenstein	$S/E \leq 2\pi R/(\hbar c)$; $\sim 2.58 \times 10^{43}$ bits for 1 kg within 1 m	Bounds storage claims
Holographic	$\sim 10^{69}$ bits per m^2 of bounding area	Information scales with area, not volume
Diffraction (Abbe)	$d = \lambda/(2 \cdot \text{NA})$; 177 nm at 514 nm with NA 1.45 - a visible-light oil-immersion reference case , not a probing figure	About 10^{28} times the Planck length . Applied instead to Section 8.4's $\sim 1.3 \mu\text{m}$ backside infrared probing the limit is far coarser, which is why a solid immersion lens (raising effective NA through silicon's high index) is what buys resolution there
Shot / radiation-pressure noise	The binding quantum limits in real instruments	LIGO beats shot noise with frequency-dependent squeezing - 4.0 dB at Hanford, 5.8 dB at Livingston near 1 kHz, 15-18% range improvement - using 300 m filter cavities. Superresolution likewise shows the diffraction limit is not an absolute wall

The last row is the honest counterweight: **these floors are engineering constraints, not guarantees**. Squeezing beats shot noise; superresolution beats Abbe. When a control depends on an adversary being stopped by a physical limit, state which limit, its value, and whether known techniques already circumvent it.

A.5 The reproducible negative

Two independent adversarial searches - one pairing Planck terminology with attack-surface, threat-model and CVE vocabulary, one searching the exact strings "Planck-length intrusion", "Planck scale attack" and "sub-Planck side channel" against the security corpus - returned **zero** security-domain uses. Hits were either ordinary side-channel/QKD security literature with no Planck content, or physics literature with no security content.

This is an absence-of-evidence result over accessible search, and is published as such with the search strings recorded so the negative is reproducible. It is sufficient to support the Section 3 fabrication-indicator rule; it is not a proof of non-existence, and is not stated as one.

Appendix B - Primary source ledger

Every substantive claim above traces to one of these. All were retrieved and verified during authoring; each carries the evidence grade it supports. Re-verify status and availability before using any of them in a compliance evidence package.

Standards and government NIST FIPS 140-3; NIST SP 800-140F and its unfinalized Revision 1 draft; the FIPS 140-3 Implementation Guidance (last updated 16 April 2026); NIST FIPS 203, 204, 205; NIST SP 800-208; NIST SP 800-227 (final, September 2025); NIST SP 800-90B; NIST IR 8547 (initial public draft); ISO/IEC 17825:2024; ISO/IEC 20085-1:2019 and 20085-2:2020; ISO/IEC 19790:2025 and 24759:2025; Common Criteria CC:2022 Part 3; JIL "Application of Attack Potential to Smartcards and Similar Devices" v3.1 (June 2020) and v3.2.1 (February 2024); PSA Certified Attack Methods v1.3; RFC 9334 (RATS Architecture); RFC 9882 (ML-DSA in CMS); `draft-ietf-pquip-hbs-state`; IEEE 802.1AR-2018; NIST CODATA constants.

Vulnerability records (all verified against NVD) CVE-2024-37880 (Clangover - compiler-emitted secret-dependent branch in the Kyber/ML-KEM reference implementation; **distinct from KyberSlash**, which carries no CVE here); CVE-2025-6202 (Phoenix / DDR5 Rowhammer); CVE-2022-24436, CVE-2022-23823, CVE-2022-35888 (Hertzbleed - Intel, AMD, Ampere); CVE-2020-8694, CVE-2020-8695 (PLATYPUS / RAPL); CVE-2019-11157 (Plundervolt).

Peer-reviewed and preprint literature KyberSlash (TCHES 2025); single-trace NTT attacks (ePrint 2019/795); generic CCA side-channel attacks on lattice KEMs (TCHES 2020(3)); FO re-encryption oracles (ePrint 2021/849); masked-Kyber k -trace (ePrint 2021/956, simulation only); FO-skip fault attacks (TCHES 2021(2), ePrint 2021/840); laser FI on seed pointers (ePrint 2025/2009); masked/shuffled Kyber breaks (ePrint 2022/1713, 2023/1587); message-encoding single-trace (ePrint 2020/992); two-step CPA + lattice reduction (arXiv:2407.06942); ML-DSA rejection-sampling and intermediate-value attacks (ePrint 2025/214, 2023/050, 2026/056); deterministic and hedged ML-DSA fault attacks (ePrint 2018/355, 2024/138, 2024/238, 2025/904); EMFI on bit-sliced NTT (arXiv:2204.06153); masking cost studies (TCHES - Masking Kyber; ePrint 2020/1038, 2022/1406, 2024/1817); Falcon Down (ePrint 2021/772); Crowhammer (ePrint 2025/1042); SLash-DSA (arXiv:2509.13048); SPHINCS+ and WOTS+ fault work (ePrint 2023/042, 2023/1572); DPA of XMSS and SPHINCS (ePrint 2018/673); BSI/Fraunhofer AISEC laser FI on XMSS; optical fault induction (CHES 2002); simple photonic emission analysis (CHES 2012); photonic attacks on RSA (ePrint 2017/108); optical contactless probing (CHES 2016, CCS 2017 / ePrint 2017/822); EOFM/LLSI (USENIX Security 2021); electron-beam probing (ISTFA 2023); two-photon-absorption LFI (TCHES 2022); dopant-level trojans (CHES 2013) and their detection (ePrint 2014/508); A2 analog trojan (IEEE S&P 2016); counterfeit taxonomy and detection (Proc. IEEE 102(8)); LWE backdoor (ePrint 2022/1381); hash-based signatures for UEFI Secure Boot (ePrint 2021/041); ISO 17825 critiques (ePrint 2019/1013, 2022/229).

Physics (Appendix A) Minimum length from first principles (Int. J. Mod. Phys. D14, 2195, 2005) and from QM + classical GR (Phys. Rev. Lett. 93, 211101, 2004); Hossenfelder, *Living Reviews in Relativity* 16:2 (hoop conjecture status); Fermi-LAT LIV constraints (Phys. Rev. D 87, 122001, 2013) and Nature 462, 331 (2009); LHAASO GRB 221009A (Phys. Rev. Lett. 133, 071501, 2024; JCAP 04 (2024) 060); Holometer (Phys. Rev. Lett. 117, 111102, 2016; Class. Quantum Grav. 34, 165005, 2017); quantum-gravity phenomenology review (Prog. Part. Nucl. Phys. 125, 103948, 2022); Landauer verification (J. Stat. Mech. 2015, P06015); Margolus-Levitin (Physica D 120, 188, 1998); Bekenstein (Phys. Rev. D 23, 287, 1981); holographic principle (Rev. Mod. Phys. 74, 825, 2002); LIGO frequency-dependent squeezing (Phys. Rev. X 13, 041021, 2023); CERN LHC parameters.

GreyNOC - detection-engineering-first security operations. Reproducible or it didn't happen.

SOURCE: CONVENTIONS.md

CONVENTIONS

Shared reference for the GreyNOC AI · PQ · E2EE playbook collection. Cited values reflect the standards landscape as of mid-2026; verify against current NIST / IETF publications before operational use, because this space is still moving.

1. Algorithm reference

Key encapsulation (KEM) - replaces RSA / ECDH key exchange

Standard	Name	Basis	Parameter sets	Notes
FIPS 203	ML-KEM (Kyber)	Module-LWE lattice	512 / 768 / 1024	Primary KEM. ML-KEM-768 ciphertext ~1088 B
In development (final expected 2027)	HQC	Code-based (quasi-cyclic)	TBD	Backup KEM selected Mar 2025; not yet a standard ; diversity hedge vs. lattice break

Signatures - replaces RSA / ECDSA / EdDSA

Standard	Name	Basis	Parameter sets	Notes
FIPS 204	ML-DSA (Dilithium)	Module-LWE/SIS lattice	44 / 65 / 87	ML-DSA-65 is the recommended default. Sig ~3309 B, pubkey ~1952 B
FIPS 205	SLH-DSA (SPHINCS+)	Hash-based	many	Conservative backup; large sigs (~7.8-49.9 KB)
FIPS 206 (in development)	FN-DSA (Falcon)	NTRU lattice + FFT	-	Selected algorithm and expected standard name; do not claim FIPS 206 compliance until final publication
SP 800-208	LMS / XMSS	Hash-based, stateful	-	Use now for firmware/code-signing per NSA guidance

Security levels: L1 ~ AES-128, L3 ~ AES-192, L5 ~ AES-256. Grover halves symmetric strength, so for long-retention data prefer **AES-256** and **SHA-384** over AES-128/SHA-256.

Naming discipline. Use standardized names (ML-KEM, ML-DSA, SLH-DSA) in all reports, tickets, and findings. Submission names (Kyber, Dilithium, SPHINCS+) are acceptable only as parenthetical aliases. For Falcon, write **Falcon / expected FN-DSA (FIPS 206 in development)** until FIPS 206 is final. Never represent a selected algorithm, draft, or reserved standard name as a completed compliance target.

2. Hybrid TLS named groups

Hybrid = classical + PQ KEM run together; an attacker must break **both** to recover the session key. Watch for these in ClientHello / ServerHello supported_groups / key_share :

NamedGroup	Value	Composition	Client key share
X25519MLKEM768	0x11EC	X25519 + ML-KEM-768	~1216 B
SecP256r1MLKEM768	(impl-specific)	P-256 + ML-KEM-768	-
SecP384r1MLKEM1024	(impl-specific)	P-384 + ML-KEM-1024	-

Production support: Chrome/BoringSSL, Firefox, Cloudflare, Akamai (default Feb 2026), AWS, OpenSSL 3.5+ (native), wolfSSL, rustls, Botan. `oqs-provider` (liboqs) is the reference experimentation provider and is **not** FIPS-validated - flag it if seen in a production path.

Quick manual check (read-only inspection of a host you are authorized to test):

```
openssl s_client -connect HOST:443 -groups X25519MLKEM768 -tls1_3 </dev/null 2>/dev/null \
| grep -i "Negotiated\|group"
```

3. E2EE protocol reference

System	PQ status	Construction	Notes
Signal PQXDH	PQ initial key establishment (Level 2)	X25519 + ML-KEM, Double Ratchet	Sept 2023; PQ at handshake only
iMessage PQ3	PQ initial + ongoing rekey (Level 3)	hybrid ECDH + ML-KEM, periodic PQ rekey (~every 50 epochs)	Uses signatures over MAC; Secure Enclave signing
MLS (RFC 9420)	classical baseline; PQ ciphersuites emerging	TreeKEM group key agreement	Group E2EE; watch ciphersuite negotiation

Open problem to keep in scope: PQ *authentication* ("Level 4") is not solved at scale by PQXDH or PQ3 - both still authenticate with classical primitives. Key-transparency systems (iMessage Contact Key Verification, WhatsApp Auditable Key Directory) are the current mitigations against key-substitution MITM; monitoring them is a detection opportunity (PB-04).

4. MITRE mapping conventions

- **ATT&CK** technique IDs are referenced where an enterprise technique applies (e.g., T1040 Network Sniffing, T1557 Adversary-in-the-Middle, T1600 Weaken Encryption, T1556 Modify Authentication Process, T1110 Brute Force, T1552 Unsecured Credentials).
- **ATLAS** is referenced as **name + ID + collection version** - e.g. *LLM Prompt Injection* (AML.T0051, ATLAS 2026.06). **Both the ID and the name are versioned and both do change**, so neither is cited bare: the collection version is what makes a citation checkable. Any playbook citing ATLAS states the collection version it was written against, and a reader re-maps to whatever their platform carries at deployment time.
- The AI playbooks in this library (PB-15-PB-20) are written against the official `mitre-atlas/atlas-data` collection **version 2026.06** (format-version 6.0.0, collection `modified-date` 2026-05-27, published 2026-06-30). Verified from `dist/v6/ATLAS-2026.06.yaml`: **16 tactics** and **173 techniques** (103 parent techniques + 70 sub-techniques), of which **114 list Agentic AI** and **92 list Generative AI** among their `platforms` - every `Generative AI` technique also carries `Agentic AI`, so 114 is the union, not the sum.
- **2026.06 renamed most ML techniques to AI, and renamed some outright.** Cite the 2026.06 name: `AML.T0010` is *AI Supply Chain Compromise*, `AML.T0018` is *Manipulate AI Model* (formerly *Backdoor ML Model*), `AML.T0053` is *AI Agent Tool Invocation* (formerly *LLM Plugin Compromise*), and `AML.T0014` is

Discover AI Model Family - **not** the older *Discover ML Artifacts*, which is a different concept. Pre-2026.06 artifacts in this library (D&R-09) still carry the older names; re-map them before reuse rather than assuming they match.

- **2026.06 added purpose-built RAG and agentic techniques - map to them instead of forcing an older tag** (Section 4's "say so rather than forcing a tag" cuts both ways). The ones this collection leans on: *RAG Poisoning* (AML.T0070), *False RAG Entry Injection* (AML.T0071), *Data from AI Services: RAG Databases* (AML.T0085.000), *AI Agent Context Poisoning* (AML.T0080, with .000 Memory), *AI Agent Tool Poisoning* (AML.T0110), *Poisoned AI Agent Tool* (AML.T0011.002), *Publish Poisoned Models* (AML.T0058), *AI Supply Chain Rug Pull* (AML.T0109), *LLM Prompt Obfuscation* (AML.T0068), *LLM Prompt Self-Replication* (AML.T0061), and *Cost Harvesting: Agentic Resource Consumption* (AML.T0034.002). In particular, AML.T0031 *Erode AI Model Integrity* is **not** the tag for corpus or memory poisoning - it describes degrading the model itself, and does not apply where the model is untouched.
- ATLAS carries a `maturity` field per technique (Realized, Demonstrated, Feasible; in 2026.06 the split is 64 / 90 / 19). Quote it when severity or plausibility is in question: a technique marked *Feasible* has not been observed in the wild, and a report that implies otherwise is fabricating impact.
- Where no clean mapping exists (much PQ-migration-defect work is pre-ATT&CK), the playbook says so rather than forcing a tag.

5. Example-data conventions

- Network examples use **RFC 5737** (192.0.2.0/24, 198.51.100.0/24, 203.0.113.0/24) and **RFC 3849** (2001:db8::/32) documentation address space.
- Identities, domains, and tokens in examples are illustrative and non-attributable.
- Detection logic is **JSON-shaped pseudocode**, not a SIEM query. Translate per platform.
- **Cross-reference notation.** The library holds **three independently numbered collections**, so a bare number is never a valid citation. PB-NN always means *this* collection (AI · Post-Quantum · E2EE). A playbook in the Detection & Response collection is written D&R-NN - e.g. D&R-09 is AI / Automated Agent Abuse, while PB-09 is PQ VPN, IPsec & SSH. A playbook in the Transmission & Physical Layer collection is written TX-NN - TX-01 is RF & radio spectrum, TX-02 is nanometer-scale optical, TX-03 is PQC at the nanometer scale in silicon. Never cite a bare number across collections.

6. Rules of engagement (binds all bug-bounty playbooks)

Authorized testing only. GreyNOC operates as the submitting firm under platform programs (e.g., HackerOne / YesWeHack) or direct written engagement.

1. **No activity without scope on file.** A signed SOW or an in-scope, in-policy bug-bounty program is a precondition. Out-of-scope assets, third-party dependencies not named in scope, and chained pivots beyond the authorized boundary are prohibited.
2. **Least-impact testing.** Prefer read-only inspection (handshake/cert/token observation) over anything state-changing. No DoS, no data exfiltration beyond minimal proof, no persistence, no lateral movement unless explicitly authorized.
3. **No fabrication.** Every reported finding must be independently reproducible from the evidence in the report. No speculative severity, no invented impact, no copied CVE text passed off as original analysis. If you cannot reproduce it, it is not a finding.
4. **Data handling.** Capture the minimum proof necessary. Never retain third-party PII, secrets, or message plaintext beyond what the program permits; redact in reports.

5. **Coordinated disclosure.** Follow the program's disclosure timeline. Do not publicize before remediation/authorization.
6. **Stop conditions.** On encountering evidence of a prior real-world compromise, customer PII at rest, or anything outside scope - stop, preserve, and escalate to the program owner.

7. AI-system testing addendum (binds Playbooks 15-20)

Section 6 applies in full. AI targets add failure modes that generic web ROE does not cover, so these rules are additive and non-negotiable for any engagement against a model, an agent, an AI-backed application, or the infrastructure serving them.

1. **Classify before you submit: security defect vs. model behavior.** Most AI programs scope *security* defects - broken authn/authz, injection that crosses a trust boundary, data exposure, tenancy failures, infrastructure compromise - and explicitly route *model behavior* (jailbreaks yielding disallowed content, hallucination, bias, refusal bypass) to a separate model-safety channel. A jailbreak is a **security** finding only when it produces a concrete security consequence: an unauthorized tool invocation, access to data the tester was not entitled to, a privilege change, or code execution. Submitting content-policy bypasses to a security queue is the fastest way to lose program standing.
2. **Never generate genuinely harmful content as proof.** Demonstrate the *control failure*, not the payload. Use an inert canary, a policy-marker string, or a benign no-op tool call. If proving a finding would require producing actually weaponizable material, stop and report the control gap with the boundary evidence already in hand.
3. **Self-scoped tenancy.** Test with your own accounts, tenant, documents, keys, and agents. Cross-tenant and cross-user claims must be demonstrated between **two tenants you control**; never between yours and a real customer's.
4. **Canary discipline.** Plant uniquely identifiable inert markers - format `GNBB-CANARY-<uuid4>` - so retrieval, leakage, and propagation claims are provable and attributable, and so the target's defenders can separate your traffic from a real adversary's.
5. **Denial-of-wallet is a real harm.** Inference is metered and shared. Stay inside documented rate limits, cap total requests up front, never run volumetric fuzzing, and demonstrate a missing consumption control with the **minimum** request count that shows it - not by actually exhausting the quota, the context window, or the GPU pool.
6. **Stochastic reproducibility.** Model output is nondeterministic; one successful prompt is not a finding. Every AI finding records model and version string, sampling parameters (temperature / top-p / seed where settable), trial count, success count, observed success rate with its confidence interval, and timestamps. **The GreyNOC bar is ≥ 2 successes from a clean context across a stated trial count**, with the full trial ledger in the report - a 2/50 result is reportable as 2/50, never as "reproducible."
7. **Data you will encounter.** RAG corpora, agent memory, vector stores, and inference logs can contain third-party PII, secrets, and conversation content. Capture the minimum proof (a hash, a redacted fragment, a record count), never bulk-collect, never retain, and report immediately. Discovery of real user data is a Section 6 stop condition.
8. **Model artifacts are untrusted code.** Never load, unpickle, deserialize, or execute a model artifact, adapter, notebook, or config obtained from a target. Inspect statically, offline, in an isolated environment.
9. **Agent and tool boundaries.** A test agent must hold the least-privileged tool set that can prove the point, prefer echo/no-op tools for proof, and never chain into out-of-scope systems. You are responsible for every action your agent takes, including ones an injection induced.
10. **Be identifiable.** Where the program permits it, mark traffic (identifying header or user agent) and register test accounts, so defenders do not burn incident-response cycles on you.

- Additional stop conditions.** Stop, preserve, and escalate on: evidence another party is exploiting the same defect; any probe that begins to affect other tenants' sessions, outputs, or costs; a training-data or memory extraction that starts returning real user content; or a finding that cannot be proven without generating genuinely harmful content.

8. Defect-class registry and AI evidence notation

8.1 Defect-class prefixes

Every bug-bounty playbook in this library numbers its defect classes with a unique prefix, so a class ID is globally unambiguous in a report, a ticket, or a triage queue. Never reuse a prefix.

Prefix	Range	Owning playbook	Domain
C	C1-C15	PB-08	Cryptographic implementation & PQ migration defects
L	L1-L14	PB-16	LLM application layer
S	S1-S10	PB-17	AI supply chain & model artifacts
G	G1-G12	PB-18	Agentic systems, tools & the MCP boundary
I	I1-I10	PB-20	Inference infrastructure & multi-tenant isolation

A finding cites exactly one primary class. Chains cite the primary class and list the others in sequence (L2 -> L5 -> L6), because the chain is what carries the impact.

Three playbooks own no prefix by design. **PB-07** and **PB-15** are methodology, not catalogs - their findings carry the class of whichever catalog the defect belongs to. **PB-19** covers model *behavior*, which routes to a program's model-safety channel rather than its security queue (Section 7.1); giving those findings a class ID would invite a triager to treat them as security defects.

The TX (Transmission & Physical Layer) collection owns no prefix either. TX-01 , TX-02 and TX-03 are detection and response playbooks, not bug-bounty catalogs; their intrusion classes are descriptive (*bend-tap*, *rogue-lambda*, *ROADM/monitor*, *impersonation*, *reception-anomaly*) and are cited by name. A registry prefix would invite a triager to read a physical-medium event as an application defect. Note also that C10 in PB-08 covers **computational** side channels - timing, fault, and secret residue. Electromagnetic emanation (TX-01 Section 5.7), optical emission (TX-02 Section 6.7), and the silicon-level physical attacks in TX-03 are different physical phenomena and are deliberately not filed under C10 .

Evidence grading in the TX track. TX-03 grades every cited result - [hw] measured on named hardware, [sim] leakage-model or simulation only, [norm] normative standard text, [adv] advisory standard text, [relayed] the citing authors quote a third party, [vendor] unaudited vendor claim. Any artifact reusing that material carries the grade with it. A [sim] result tabulated beside a [hw] result without its grade visible is a reporting defect, because it overstates demonstrated capability - the same fabrication concern Section 6.3 addresses for findings.

8.2 Canary tokens

Inert markers are the sanctioned proof mechanism for AI findings (Section 7.4). Format:

GNBB-CANARY-<uuid4>	e.g. GNBB-CANARY-3f2a1c68-9d47-4e2b-8a10-5c7e9b04d1f6
---------------------	---

Canaries are registered in the engagement's canary registry before use, are unique per probe and per tenant, and carry no semantic content. A retrieval, leakage, propagation, or tool-invocation claim is proven by the canary appearing where it should not - not by narrative description.

8.3 Trial-ledger notation for stochastic findings

Per Section 7.6, AI findings report reproducibility as a ledger, never as an adjective. The canonical short form in a report title or triage summary is:

```
successes/trials @ temperature (95% CI low-high)      e.g. 7/20 @ t=1.0 (0.18-0.57)
```

Report templates may label the interval **95% Wilson CI** where the form needs to be unambiguous; the short form above stays canonical for titles and triage summaries.

The interval is a **Wilson score interval** - with the small trial counts an authorized, rate-limited engagement can afford, a normal-approximation interval is wrong at the tails and a bare percentage is meaningless. **2/50** is reported as **2/50**, and is still a real finding when the consequence is real and the attacker's retry cost is low; severity comes from consequence and retry economics, not from the rate alone.

9. Versioned reference baseline

These sources are the audit baseline for the collection. Record the retrieval date in any compliance evidence package and re-check status before deployment:

- NIST Post-Quantum Cryptography project - authoritative status for FIPS 203/204/205, FIPS 206 development, HQC selection, and future PQ standards.
- NIST SP 800-227 - KEM construction and implementation guidance.
- NIST CSWP 39-upd1 - final June 2026 crypto-agility guidance.
- IETF ECDHE-MLKEM TLS draft and the IANA TLS Supported Groups registry - current protocol status and code points; an Internet-Draft is not an RFC.
- NIST AI RMF and NIST AI 600-1 GenAI Profile - enterprise AI governance, mapping, measurement, and management baseline.
- NIST CSF 2.0 - Govern, Identify, Protect, Detect, Respond, and Recover outcomes.
- CISA JCDC AI Cybersecurity Collaboration Playbook - AI incident coordination and information-sharing baseline.
- OWASP Top 10 for LLM Applications 2025 and OWASP Top 10 for Agentic Applications 2026 - application and agentic risk cross-checks.
- Executive Order 14412 fact sheet and OMB M-23-02 - federal PQ migration direction; determine applicability before treating either as binding.
- PCI SSC FAQ 1491 - PQ TLS is described as best practice; PCI DSS does not currently impose a general PQ migration mandate.

GreyNOC - detection-engineering-first. Reproducible or it didn't happen.